

Báo cáo Lỗi (Bug Report) - HW02

Thông tin sinh viên

- Họ và tên: Lê Mai Hoài Bảo
- MSSV: 23127326

1. Danh sách lỗi tổng hợp (Bug List)

Dưới đây là danh sách các lỗi phát hiện được đối với các tính năng **FR-02**, **FR-09**, **FR-17** và **FR-07** dựa trên việc chạy thực tế và đối chiếu hành vi của hệ thống (ở mức Giao diện UI và API phản hồi) với tài liệu đặc tả yêu cầu (Kiểm thử hộp đen - Black-box testing):

1.1. Pool A: FR-02: Đăng nhập & Khóa tài khoản

Mã Bug	Tên lỗi (Bug Name)	Mã TC phát hiện	Mô tả hành vi lỗi quan sát	Độ nghiêm trọng (Severity)	Trạng thái
BUG-FR02-01	Tài khoản bị tạm khóa sớm sau 2 lần đăng nhập sai liên tiếp (lần thứ 3 bị chặn)	TC05, TC-BVA-02, TC-BVA-03	Tài khoản bị khóa ngay sau 2 lần đăng nhập sai liên tiếp (lần thứ 3 bị chặn 403), trong khi đặc tả yêu cầu sai từ 3 lần liên tiếp mới khóa (lần thứ 4 mới bị chặn 403).	High	Open
BUG-FR02-02	Tài khoản không tự động mở khóa sau 30 giây như đặc tả	TC-BVA-07	Khi tài khoản bị tạm khóa, tài khoản vẫn tiếp tục bị khóa và không tự động mở khóa sau thời hạn 30 giây như quy định của đặc tả.	High	Open
BUG-FR02-03	API đăng nhập thành công trả về trường mật khẩu dưới dạng văn bản rõ (plaintext)	TC01, TC-BVA-01	Payload phản hồi của API khi đăng nhập thành công chứa thuộc tính mật khẩu người dùng, gây nguy cơ rò rỉ dữ liệu nhạy cảm.	Critical	Open
BUG-FR02-04	Trường Email trên giao diện Web và Admin không kiểm tra định dạng HTML5 ở client	TC03	Trường Email đăng nhập sử dụng thẻ input có type="text" thay vì type="email", cho phép gửi dữ liệu email sai định dạng lên backend.	High	Open
BUG-FR02-05	Hệ thống không vô hiệu hóa phiên làm việc (JWT Token)	TC09	JWT Token cũ đã cấp từ trước vẫn có quyền gọi API lấy dữ liệu nhạy cảm bình thường ngay cả	Critical	Open

Mã Bug	Tên lỗi (Bug Name)	Mã TC phát hiện	Mô tả hành vi lỗi quan sát	Độ nghiêm trọng (Severity)	Trạng thái
	cũ khi tài khoản bị tạm khóa		khi tài khoản đã bị khóa ở session khác.		
BUG-FR02-06	API đăng nhập không phản hồi rõ ràng cho email sai định dạng khi gọi trực tiếp	TC10	Khi gửi trực tiếp email sai định dạng tới <code>/api/login</code> , API vẫn trả lỗi đăng nhập chung thay vì lỗi validation định dạng email theo yêu cầu kiểm tra input.	Low	Open
BUG-FR02-07	Lỗi hỏng Race Condition cho phép gửi song song nhiều request vượt cơ chế khóa	TC08	Khi gửi 5 request đăng nhập sai đồng thời qua API trong 1ms, tất cả đều được xử lý thành công (trả về 401) thay vì bị chặn từ lần 3.	High	Open

1.2. Pool B: FR-09: Mã Giảm Giá (Coupon)

Mã Bug	Tên lỗi (Bug Name)	Mã TC phát hiện	Mô tả hành vi lỗi quan sát	Độ nghiêm trọng (Severity)	Trạng thái
BUG-FR09-01	Lỗi tính toán sai số tiền được giảm cho coupon loại phần trăm (percent)	TC01, TC-BVA-03, TC-BVA-06	Coupon phần trăm (ví dụ giảm 10% cho đơn 500,000 đ) bị tính sai công thức khiến giá trị discount bị âm (-4,500,000 đ) và tổng tiền cuối cùng tăng vọt (5,000,000 đ).	High	Open
BUG-FR09-02	So sánh sai biên tối thiểu khiến đơn hàng bằng đúng ngưỡng tối thiểu bị từ chối	TC-BVA-01	Đơn hàng có tổng tiền đúng bằng ngưỡng tối thiểu áp dụng mã (300,000 đ) vẫn bị hệ thống báo lỗi không đủ điều kiện tối thiểu.	High	Open
BUG-FR09-03	Lỗi hỏng API kiểm tra mã giảm giá (<code>/api/apply-coupon</code>) không xác thực Token JWT	TC11	API <code>/api/apply-coupon</code> không yêu cầu xác thực JWT, cho phép bất kỳ ai (kể cả chưa đăng nhập) gọi API thành công.	Critical	Open
BUG-FR09-04	Hệ thống cho phép giả mạo <code>user_id</code> (ID Spoofing) hoặc bỏ trống <code>user_id</code> khi áp dụng mã giảm giá	TC09, TC10	API vẫn chấp nhận request khi <code>user_id</code> trong body không khớp người dùng đang đăng nhập, hoặc khi	Critical	Open

Mã Bug	Tên lỗi (Bug Name)	Mã TC phát hiện	Mô tả hành vi lỗi quan sát	Độ nghiêm trọng (Severity)	Trạng thái
			thiếu <code>user_id</code> , thay vì ràng buộc theo JWT hợp lệ.		
BUG-FR09-05	Lỗi hỏng Checkout Bypass - API thanh toán (<code>/api/checkout</code>) không xác thực lại các điều kiện mã giảm giá	TC15	API <code>/api/checkout</code> nhận trực tiếp tổng số tiền đã giảm từ body mà không kiểm tra hay validate lại tính hợp lệ của mã giảm giá trên backend.	Critical	Open
BUG-FR09-06	Lỗi xử lý thông điệp phản hồi không khớp cho dữ liệu đầu vào không hợp lệ (số tiền âm hoặc sai kiểu dữ liệu)	TC07, TC08	Khi gửi số tiền âm (-50k) hoặc sai kiểu chữ, hệ thống báo lỗi sai nghiệp vụ: "Đơn hàng chưa đủ giá trị tối thiểu..." thay vì báo lỗi định dạng/số tiền không hợp lệ.	Medium	Open
BUG-FR09-07	Lỗi hỏng Race Condition (Double Apply) cho phép áp dụng mã giới hạn 1 lần nhiều lần	TC14	Gửi đồng thời các request áp dụng mã qua endpoint công khai <code>/api/apply-coupon</code> trong cùng 1ms đều được chấp nhận, thay vì chỉ cho phép một request thành công.	High	Open

1.3. Pool C: FR-17: Quản lý Mã Giảm Giá (Coupon CRUD)

Mã Bug	Tên lỗi (Bug Name)	Mã TC phát hiện	Mô tả hành vi lỗi quan sát	Độ nghiêm trọng (Severity)	Trạng thái
BUG-FR17-01	API Admin tạo coupon không kiểm tra role Admin	TC05	Token của user thường vẫn gọi <code>POST /api/admin/coupons</code> thành công và tạo coupon mới với HTTP 200.	Critical	Open
BUG-FR17-02	API tạo coupon không validate trường <code>code</code> bắt buộc	TC06, TC-BVA-01	Backend vẫn tạo coupon khi <code>code</code> rỗng, trong khi mã giảm giá là trường bắt buộc và phải định danh được coupon.	High	Open
BUG-FR17-03	API tạo coupon không validate miền giá trị <code>type</code>	TC08, TC09	Backend vẫn tạo coupon khi <code>type</code> ngoài tập cho phép hoặc thiếu <code>type</code> , thay vì chỉ chấp nhận <code>percent</code> hoặc <code>fixed</code> .	High	Open

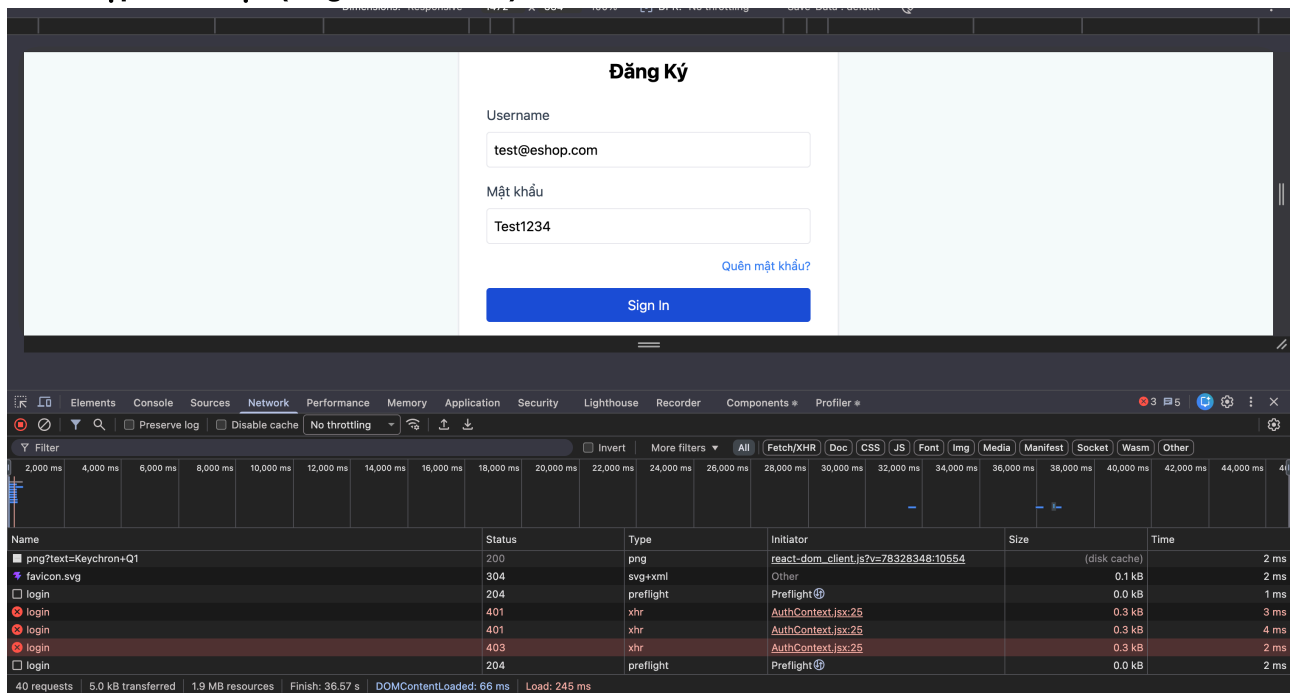
Mã Bug	Tên lỗi (Bug Name)	Mã TC phát hiện	Mô tả hành vi lỗi quan sát	Độ nghiêm trọng (Severity)	Trạng thái
BUG-FR17-04	API tạo coupon không validate <code>discount_value</code>	TC10, TC11, TC12, TC-BVA-03	Backend vẫn tạo coupon khi <code>discount_value</code> bằng 0, âm hoặc sai kiểu dữ liệu.	High	Open
BUG-FR17-05	API tạo coupon không validate <code>expired_at</code>	TC13, TC14	Backend vẫn tạo coupon khi thiếu ngày hết hạn hoặc ngày hết hạn sai định dạng.	High	Open
BUG-FR17-06	API tạo coupon không validate <code>min_order_amount</code>	TC15, TC16, TC-BVA-05	Backend vẫn tạo coupon khi giá trị đơn tối thiểu âm hoặc sai kiểu dữ liệu.	High	Open
BUG-FR17-07	API tạo coupon không validate <code>max_uses_per_user</code>	TC17, TC-BVA-07	Backend vẫn tạo coupon khi số lượt dùng tối đa mỗi user bằng 0, vi phạm miền hợp lệ tối thiểu 1.	High	Open
BUG-FR17-08	Tạo coupon trùng mã trả lỗi 500 và lộ lỗi SQLite	TC07, TC19	Khi <code>code</code> bị trùng, API trả HTTP 500 kèm thông báo <code>SQLITE_CONSTRAINT</code> , thay vì lỗi nghiệp vụ/validation về mã đã tồn tại.	Medium	Open
BUG-FR17-09	Xóa coupon không tồn tại vẫn báo thành công	TC18, TC-BVA-09	<code>DELETE /api/admin/coupons/999999</code> và <code>DELETE /api/admin/coupons/0</code> đều trả HTTP 200 với thông báo xóa thành công dù không có coupon hợp lệ bị xóa.	High	Open

2. Chi tiết các lỗi (Detailed Bug Descriptions)

Pool A: FR-02: Đăng nhập & Khóa tài khoản

BUG-FR02-01: Tài khoản bị tạm khóa sớm sau 2 lần đăng nhập sai liên tiếp (lần thứ 3 bị chặn)

- **Mô tả lỗi:** Theo đặc tả yêu cầu, tài khoản chỉ bị tạm khóa khi đăng nhập sai từ 3 lần trở lên liên tiếp (tức lần nhập sai thứ 3 vẫn trả về lỗi đăng nhập thường, và lần đăng nhập thứ 4 mới bị chặn). Tuy nhiên trên thực tế, người dùng bị chặn đăng nhập ngay từ lần đăng nhập thứ 3 (chỉ mới đăng nhập sai 2 lần trước đó).
- **Các bước tái hiện (Steps to Reproduce):**
 1. Nhập đúng email đăng ký và mật khẩu **sai**, bấm nút Đăng nhập → Hệ thống báo lỗi *"Invalid email or password"*. (Lần sai thứ 1)
 2. Nhập đúng email đăng ký và mật khẩu **sai**, bấm nút Đăng nhập → Hệ thống báo lỗi *"Invalid email or password"*. (Lần sai thứ 2)
 3. Nhập đúng email đăng ký và mật khẩu **đúng/sai**, bấm nút Đăng nhập → Hệ thống lập tức trả về lỗi *"Tài khoản đã bị khóa. Vui lòng thử lại sau."* và mã HTTP 403. (Lần thứ 3)
- **Kết quả mong đợi (Expected Output):**
 - Lần thứ 1 và 2: Trả về mã lỗi đăng nhập không chính xác **401 Unauthorized**.
 - Lần thứ 3: Tiếp tục trả về mã lỗi đăng nhập không chính xác **401 Unauthorized** (vì đây là lần sai thứ 3, chưa bị chặn trước đó).
 - Lần thứ 4: Hệ thống mới chặn đăng nhập với mã **403 Forbidden** do tài khoản đã bị tạm khóa.
- **Kết quả thực tế (Actual Output):** Tài khoản đã bị khóa ngay sau lần nhập sai thứ 2. Do đó, đến lần thứ 3 (khi bấm Đăng nhập), hệ thống đã chặn ngay lập tức và trả về mã lỗi **403 Forbidden** cùng thông báo khóa tài khoản.
- **Đường dẫn GitHub Issue:** [GitHub Issue #1](#)
- **Ảnh chụp minh họa (Bug Screenshot):**

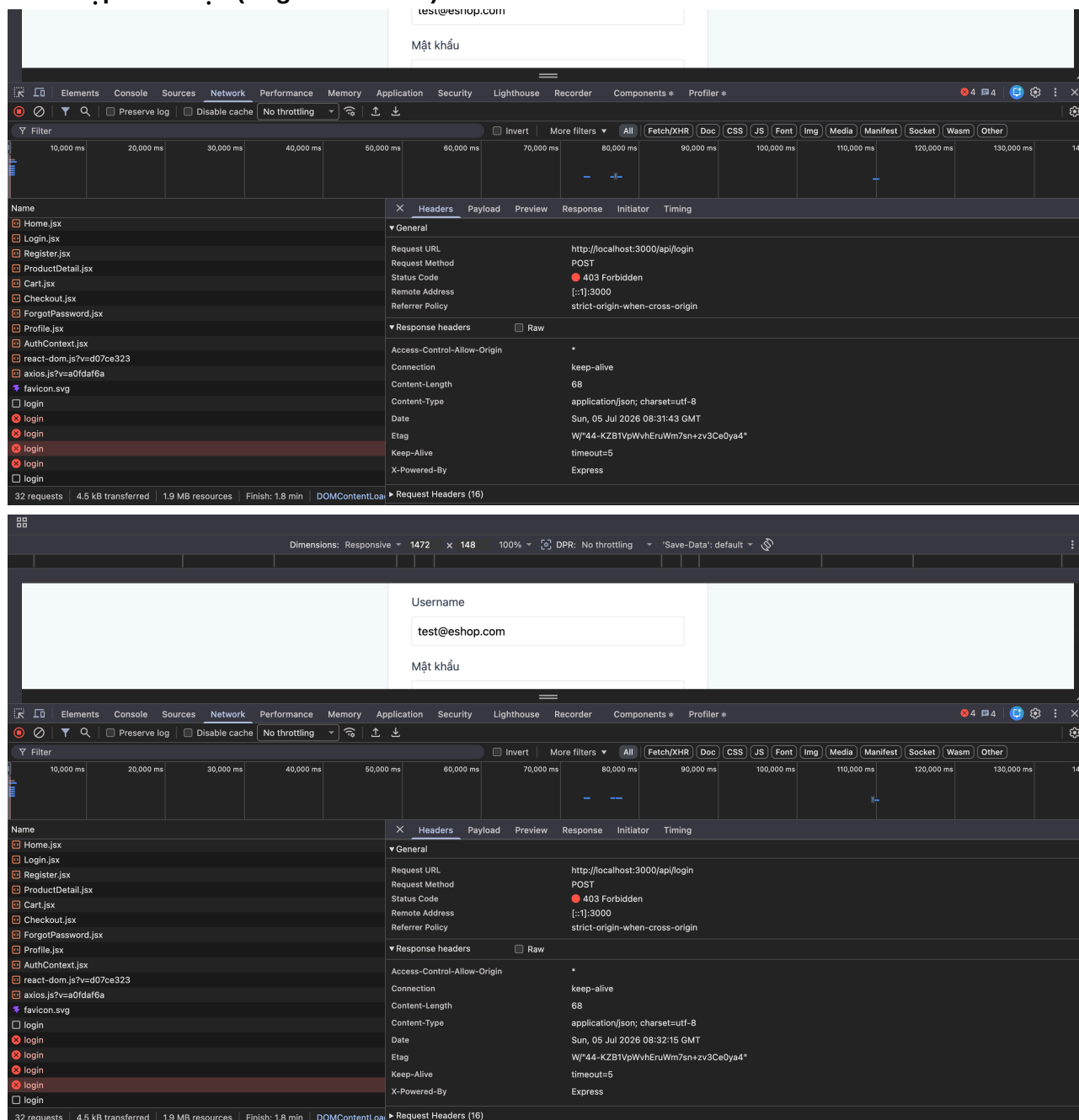


BUG-FR02-02: Tài khoản không tự động mở khóa sau 30 giây như đặc tả

- **Mô tả lỗi:** Đặc tả quy định trong môi trường demo, thời gian tạm khóa tài khoản khi nhập sai là 30 giây. Nhưng khi bị khóa, tài khoản vẫn tiếp tục bị giữ ở trạng thái khóa và không tự động mở lại sau 30 giây.
- **Các bước tái hiện (Steps to Reproduce):**
 1. Thực hiện đăng nhập sai liên tiếp cho đến khi tài khoản kích hoạt trạng thái bị khóa.

- Chờ 40 giây (lớn hơn thời gian khóa 30 giây quy định).
- Nhập địa chỉ email và mật khẩu **chính xác**, bấm nút Đăng nhập.

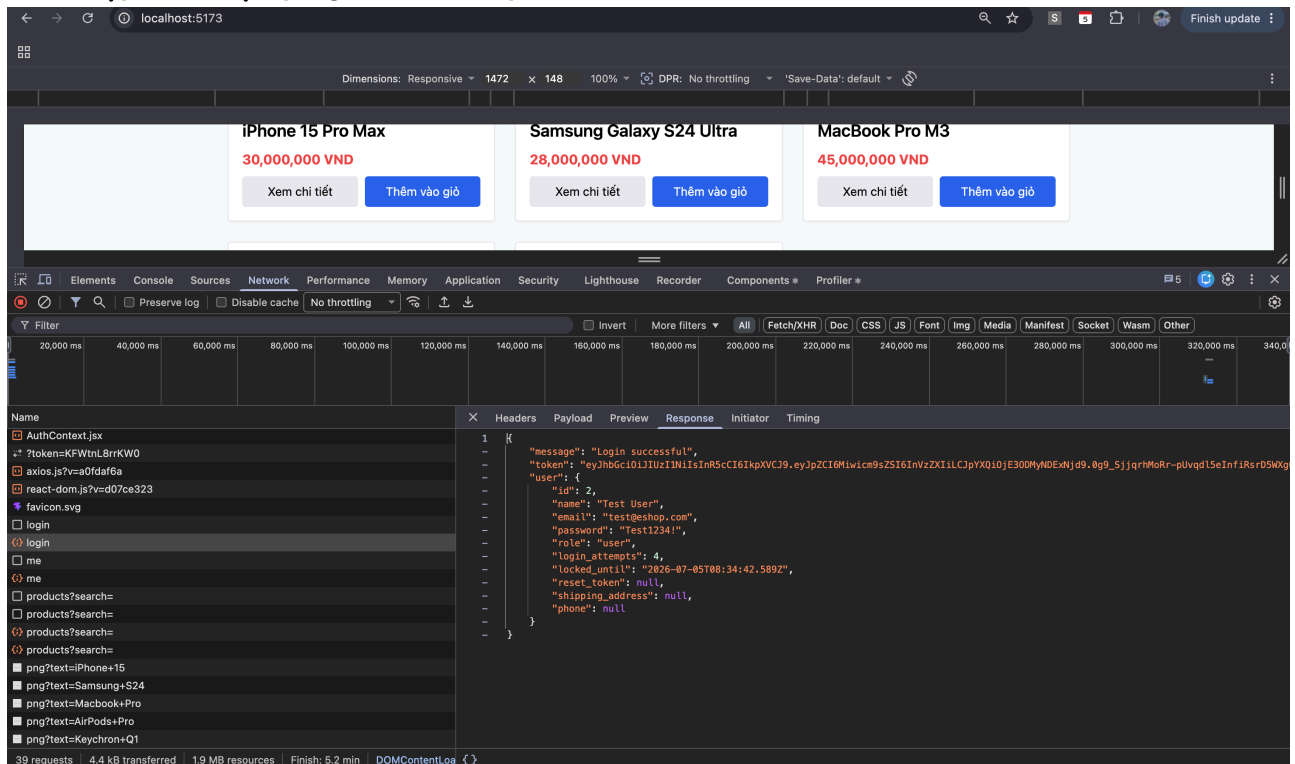
- Kết quả mong đợi (Expected Output):** Đăng nhập thành công và nhận JWT Token phía client vì đã hết thời gian khóa 30 giây theo đặc tả.
- Kết quả thực tế (Actual Output):** Đăng nhập thất bại, hệ thống vẫn trả về thông báo lỗi báo tài khoản đang bị khóa (tài khoản không tự động mở khóa sau 30 giây).
- Đường dẫn GitHub Issue:** [GitHub Issue #2](#)
- Ảnh chụp minh họa (Bug Screenshot):**



BUG-FR02-03: API đăng nhập thành công trả về trường mật khẩu dưới dạng văn bản rõ (plaintext)

- Mô tả lỗi:** Khi người dùng gửi yêu cầu đăng nhập thành công, dữ liệu phản hồi (JSON response) trả về từ backend API chứa cả thông tin mật khẩu của tài khoản ở định dạng văn bản thô rõ ràng, vi phạm nguyên tắc an toàn thông tin cơ bản.
- Các bước tái hiện (Steps to Reproduce):**

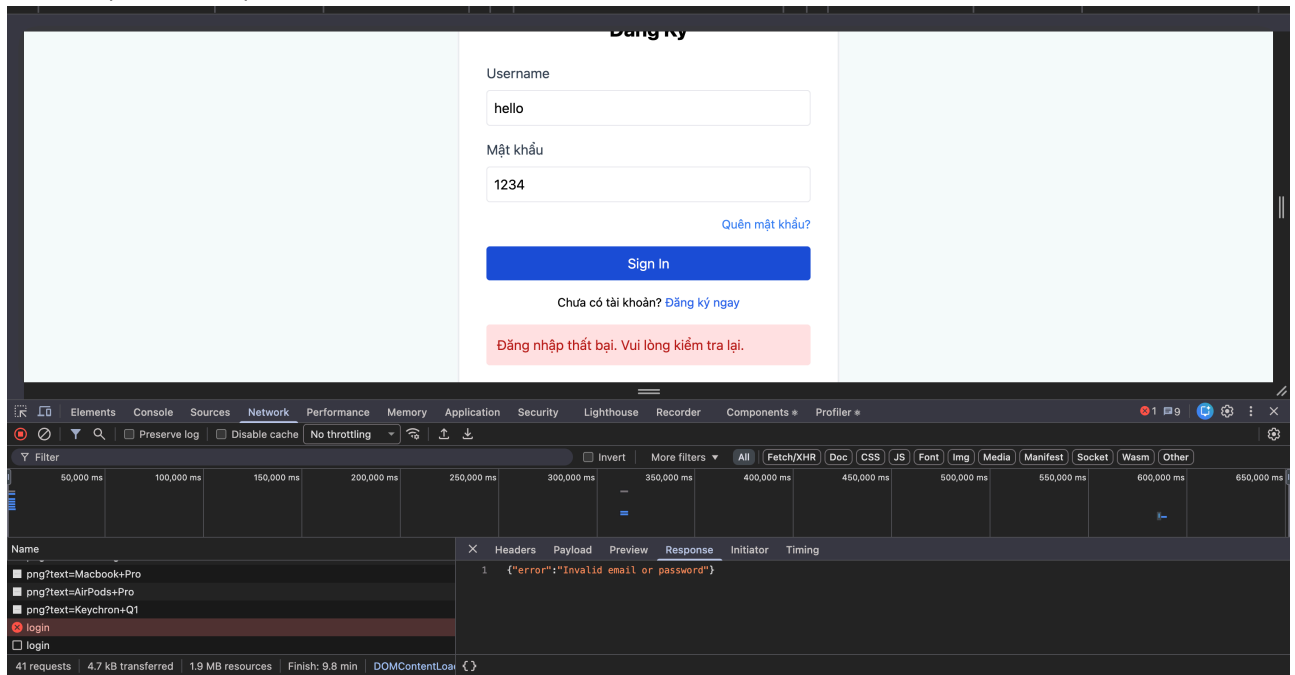
- Sử dụng công cụ Postman/cURL hoặc kiểm tra tab Network trên trình duyệt, gửi request POST tới `/api/login` với email và mật khẩu chính xác.
 - Quan sát cấu trúc dữ liệu JSON phản hồi ở body của response `200 OK`.
- Kết quả mong đợi (Expected Output):** JSON phản hồi chứa JWT token và thông tin cơ bản của user như `id`, `name`, `email`, `role`. Tuyệt đối không được chứa trường `password` hoặc `reset_token`.
 - Kết quả thực tế (Actual Output):** Dữ liệu JSON phản hồi chứa thuộc tính `"password": "Test1234!"` hiển thị rõ ràng mật khẩu plaintext của tài khoản.
 - Đường dẫn GitHub Issue:** [GitHub Issue #3](#)
 - Ảnh chụp minh họa (Bug Screenshot):**



BUG-FR02-04: Trường Email trên giao diện Web và Admin không kiểm tra định dạng HTML5 ở client

- Mô tả lỗi:** Theo đặc tả nghiệp vụ, trường email của biểu mẫu đăng nhập bắt buộc phải dùng `type="email"` để thực hiện kiểm tra (validate) định dạng email theo chuẩn HTML5. Tuy nhiên, trên giao diện Web và Admin, trường Email sử dụng `type="text"`, cho phép người dùng bấm gửi dữ liệu sai định dạng (thiếu ký tự @, tên miền...) lên server mà không bị chặn lại ở trình duyệt.
- Các bước tái hiện (Steps to Reproduce):**
 - Mở màn hình Đăng nhập của Web (hoặc Admin).
 - Nhập địa chỉ email sai định dạng: `invalid-email.com` vào trường Email.
 - Nhập mật khẩu bất kỳ và nhấn Đăng nhập.
- Kết quả mong đợi (Expected Output):** Trình duyệt tự động chặn lại và hiển thị cảnh báo lỗi định dạng của trường email (HTML5 validation), không gửi request lên backend API.
- Kết quả thực tế (Actual Output):** Form đăng nhập cho phép submit thành công, gửi thẳng request POST `/api/login` có email sai định dạng lên backend và nhận về phản hồi lỗi `401 Unauthorized` từ server.
- Đường dẫn GitHub Issue:** [GitHub Issue #4](#)

- Ảnh chụp minh họa (Bug Screenshot):



BUG-FR02-05: Hệ thống không vô hiệu hóa phiên làm việc (JWT Token) cũ khi tài khoản bị tạm khóa

- Mô tả lỗi:** Khi tài khoản bị tạm khóa (do có các hoạt động đăng nhập sai liên tiếp ở session khác), hệ thống không thực hiện thu hồi hoặc vô hiệu hóa các JWT Token cũ đã cấp từ trước của tài khoản đó. Người dùng/kẻ tấn công đang nắm giữ token cũ này vẫn có thể thực hiện thành công các truy vấn có xác thực để lấy thông tin nhạy cảm.
- Các bước tái hiện (Steps to Reproduce):**
 - Đăng ký tài khoản mới và thực hiện đăng nhập thành công ở Thiết bị A để lấy JWT Token hợp lệ.
 - Ở Thiết bị B, thực hiện đăng nhập sai 2 lần liên tiếp để đưa tài khoản vào trạng thái tạm khóa.
 - Ở Thiết bị A, sử dụng JWT Token đã lấy ở bước 1 để gửi request `GET /api/users/me` (đây là endpoint yêu cầu xác thực).
- Kết quả mong đợi (Expected Output):** Server từ chối request và trả về mã lỗi **401 Unauthorized** hoặc **403 Forbidden** vì tài khoản tương ứng đang bị khóa.
- Kết quả thực tế (Actual Output):** API vẫn trả về **200 OK** kèm theo toàn bộ thông tin cá nhân và mật khẩu chưa mã hóa của tài khoản, bất chấp trạng thái tài khoản đang bị khóa theo luồng kiểm thử.
- Đường dẫn GitHub Issue:** [GitHub Issue #5](#)

- Ảnh chụp minh họa (Bug Screenshot):

```
● (base) HB4305 ~/KhoChua/DH/Năm3/HK3/Kiểm thử phần mềm/HW02 % node scratch_test_token.js
=== BẮT ĐẦU KIỂM THỬ TOKEN KHI TÀI KHOẢN BỊ KHÓA (TC09) ===
1. Đăng ký thành công tài khoản: token_test_1783241637979@eshop.com
2. Thiết bị A đăng nhập thành công. Nhận JWT Token: Thành công (đã lấy được token)
3. Thiết bị B gửi 2 request đăng nhập sai mật khẩu liên tiếp để khóa tài khoản...
4. Thiết bị A gọi API `/api/users/me` sử dụng JWT Token cũ...

Kết quả gọi API: HTTP Status = 200
Response JSON: {
  id: 6,
  name: 'Token Test User',
  email: 'token_test_1783241637979@eshop.com',
  password: 'Test1234!',
  role: 'user',
  login_attempts: 4,
  locked_until: '2026-07-05T08:56:58.042Z',
  reset_token: null,
  shipping_address: null,
  phone: null
}

-> KẾT QUẢ: Hệ thống VẪN CHO PHÉP truy cập API bằng token cũ mặc dù tài khoản đã bị khóa!
=== KẾT THÚC KIỂM THỬ ===
○ (base) HB4305 ~/KhoChua/DH/Năm3/HK3/Kiểm thử phần mềm/HW02 % █
```

```

1 // scratch_test_token.js
2 // Script test session/token invalidation (TC09)
3 // Hãy chắc chắn rằng backend server đang chạy tại http://localhost:3000
4
5 const email = `token_test_${Date.now()}@eshop.com`;
6 const password = 'Test1234!';
7 const wrongPassword = 'WrongPassword!';
8
9 const runTokenTest = async () => {
10   console.log("=== BẮT ĐẦU KIỂM THỬ TOKEN KHI TÀI KHOẢN BỊ KHÓA (TC09) ===");
11
12   // 1. Đăng ký tài khoản sạch
13   await fetch('http://localhost:3000/api/register', {
14     method: 'POST',
15     headers: { 'Content-Type': 'application/json' },
16     body: JSON.stringify({ name: 'Token Test User', email, password })
17   });
18   console.log(`1. Đăng ký thành công tài khoản: ${email}`);
19
20   // 2. Đăng nhập thành công trên Thiết bị A để lấy JWT Token
21   const loginRes = await fetch('http://localhost:3000/api/login', {
22     method: 'POST',
23     headers: { 'Content-Type': 'application/json' },
24     body: JSON.stringify({ email, password })
25   });
26   const loginData = await loginRes.json();
27   const token = loginData.token;
28   console.log(`2. Thiết bị A đăng nhập thành công. Nhận JWT Token:`, token ? "Thành công (đã lấy được token)" : "Thất bại");
29
30   // 3. Giả lập Thiết bị B nhập sai 2 lần liên tiếp khiến tài khoản bị khóa
31   console.log(`3. Thiết bị B gửi 2 request đăng nhập sai mật khẩu liên tiếp để khóa tài khoản...`);
32   await fetch('http://localhost:3000/api/login', {
33     method: 'POST',
34     headers: { 'Content-Type': 'application/json' },
35     body: JSON.stringify({ email, password: wrongPassword })
36   });
37   await fetch('http://localhost:3000/api/login', {
38     method: 'POST',
39     headers: { 'Content-Type': 'application/json' },
40     body: JSON.stringify({ email, password: wrongPassword })
41   });
42
43   // 4. Thiết bị A dùng Token cũ để truy cập endpoint bảo mật /api/users/me
44   console.log(`4. Thiết bị A gọi API '/api/users/me' sử dụng JWT Token cũ...`);
45   try {
46     const meRes = await fetch('http://localhost:3000/api/users/me', {
47       method: 'GET',
48       headers: {
49         'Authorization': `Bearer ${token}`,
50         'Content-Type': 'application/json'
51       }
52     });
53     const status = meRes.status;
54     const meData = await meRes.json();
55     console.log(`\nKết quả gọi API: HTTP Status = ${status}`);
56     console.log("Response JSON:", meData);
57
58     if (status === 200) {
59       console.log("\n-> KẾT QUẢ: Hệ thống VẪN CHO PHÉP truy cập API bằng token cũ mặc dù tài khoản đã bị khóa!");
60     } else {
61       console.log("\n-> KẾT QUẢ: Hệ thống đã chặn thành công token cũ khi tài khoản bị khóa.");
62     }
63   } catch (err) {
64     console.error("Lỗi khi gọi API me:", err.message);
65   }
66   console.log("=== KẾT THÚC KIỂM THỬ ===");
67 };
68
69 runTokenTest();
70

```

BUG-FR02-06: API đăng nhập không phản hồi rõ ràng cho email sai định dạng khi gọi trực tiếp

- Mô tả lỗi:** Khi gọi trực tiếp endpoint `/api/login` với email sai định dạng, API không trả lỗi validation định dạng email. Hệ thống phản hồi lỗi đăng nhập chung, khiến phía API không thể hiện rõ ràng yêu cầu kiểm tra email hợp lệ như đặc tả.
- Các bước tái hiện (Steps to Reproduce):**
 - Dùng Postman hoặc cURL gửi trực tiếp request POST tới `http://localhost:3000/api/login` với body: `{"email": "notanemail", "password": "Test1234!"}`.
 - Kiểm tra response trả về từ server.
- Kết quả mong đợi (Expected Output):** Server từ chối input sai định dạng và trả về mã lỗi `400 Bad Request` hoặc `401 Unauthorized` kèm thông báo phù hợp về email không hợp lệ.

- **Kết quả thực tế (Actual Output):** Server trả lỗi đăng nhập chung **401 Unauthorized** cho chuỗi 'notanemail', không có phản hồi validation riêng cho định dạng email sai.
- **Đường dẫn GitHub Issue:** [GitHub Issue #6](#)
- **Ảnh chụp minh họa (Bug Screenshot):**

```
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -i -X POST http://localhost:3000/api/login \
-H "Content-Type: application/json" \
-d '{"email": "notanemail", "password": "Test1234!"}'
HTTP/1.1 401 Unauthorized
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 37
ETag: W/"25-3YG4LRpklFolV4uV0nUIRm2hZA0"
Date: Sun, 05 Jul 2026 09:01:11 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"error":"Invalid email or password"}
```

BUG-FR02-07: Lỗi hỏng Race Condition cho phép gửi song song nhiều request vượt cơ chế khóa

- **Mô tả lỗi:** Khi gửi nhiều request đăng nhập sai song song trong thời gian rất ngắn, hệ thống không chặn kịp theo ngưỡng khóa tài khoản. Đây là hành vi quan sát được qua API công khai và cho thấy cơ chế xử lý đồng thời của luồng đăng nhập chưa đáp ứng đặc tả khóa sau 3 lần sai liên tiếp.
- **Các bước tái hiện (Steps to Reproduce):**
 1. Sử dụng kịch bản Node.js **scratch_test_race.js** gửi đồng thời 5 request đăng nhập sai mật khẩu của cùng 1 tài khoản trong cùng 1 mili giây.
 2. Quan sát mã phản hồi HTTP trả về từ server cho cả 5 request.
- **Kết quả mong đợi (Expected Output):** Hệ thống chỉ cho phép tối đa 2 request đầu tiên trả về **401 Unauthorized** (vì ngưỡng khóa là 3 lần sai). Các request thứ 3, 4, 5 phải bị chặn và trả về **403 Forbidden**.
- **Kết quả thực tế (Actual Output):** Cả 5 request song song đều trả về mã lỗi **401 Unauthorized** cùng lúc và không có request nào bị chặn bằng mã **403 Forbidden** trong loạt gửi song song đó. Tài khoản chỉ bị khóa sau khi loạt request này đã thực thi xong.
- **Đường dẫn GitHub Issue:** [GitHub Issue #7](#)

• Ảnh chụp minh họa (Bug Screenshot):

```
// scratch_test_race.js
// Script test Race Condition (Brute-force song song) cho TC08
// Đăng ký tài khoản sạch, gửi 5 request đồng thời, sau đó đăng nhập bằng mật khẩu đúng

const email = `race_${Date.now()}@eshop.com`; // Tạo email ngẫu nhiên
const password = 'Test1234!';
const wrongPassword = 'WrongPassword!';

const registerUser = async () => {
  try {
    const res = await fetch('http://localhost:3000/api/register', {
      method: 'POST',
      headers: { 'Content-Type': 'application/json' },
      body: JSON.stringify({ name: 'Race Test User', email, password })
    });
    const data = await res.json();
    console.log("Đăng ký tài khoản test mới:", email, data.message || data.error);
  } catch (err) {
    console.error("Lỗi khi đăng ký:", err.message);
  }
};

const makeRequest = async (id) => {
  try {
    const res = await fetch('http://localhost:3000/api/login', {
      method: 'POST',
      headers: { 'Content-Type': 'application/json' },
      body: JSON.stringify({ email, password: wrongPassword })
    });
    const status = res.status;
    const data = await res.json();
    console.log(`Request ${id}: HTTP Status = ${status} - Response:`, data);
  } catch (err) {
    console.error(`Request ${id}: Lỗi -`, err.message);
  }
};

const verifyLogin = async () => {
  try {
    const res = await fetch('http://localhost:3000/api/login', {
      method: 'POST',
      headers: { 'Content-Type': 'application/json' },
      body: JSON.stringify({ email, password })
    });
    const status = res.status;
    const data = await res.json();
    console.log(`\nĐăng nhập lại bằng mật khẩu ĐÚNG: HTTP Status = ${status} - Response:`, data);
  } catch (err) {
    console.error("Lỗi khi đăng nhập lại:", err.message);
  }
};

const runRaceTest = async () => {
  console.log("=== BẮT ĐẦU KIỂM THỬ RACE CONDITION (TC08) ===");
  await registerUser();

  console.log("\nGửi đồng thời 5 request đăng nhập sai...");
  const promises = [];
  for (let i = 1; i <= 5; i++) {
    promises.push(makeRequest(i));
  }

  await Promise.all(promises);

  // Chờ 500ms để đảm bảo các update database đã được thực thi xong
  await new Promise(resolve => setTimeout(resolve, 500));

  await verifyLogin();
  console.log("\n=== KẾT THÚC KIỂM THỬ ===");
};

runRaceTest();
```

Chat %L ... @mermaid-chart

> Generate Mermaid Diagram

```
• (base) HB4305 ~/KhoChua/BH/Năm3/HK3/Kiểm thử phần mềm/HW02 % node scratch_test_race.js
=== BẮT ĐẦU KIỂM THỬ RACE CONDITION (TC08) ===
Đăng ký tài khoản test mới: race_1783242817323@eshop.com User registered successfully

Gửi đồng thời 5 request đăng nhập sai...
Request 1: HTTP Status = 401 - Response: { error: 'Invalid email or password' }
Request 2: HTTP Status = 401 - Response: { error: 'Invalid email or password' }
Request 3: HTTP Status = 401 - Response: { error: 'Invalid email or password' }
Request 4: HTTP Status = 401 - Response: { error: 'Invalid email or password' }
Request 5: HTTP Status = 401 - Response: { error: 'Invalid email or password' }

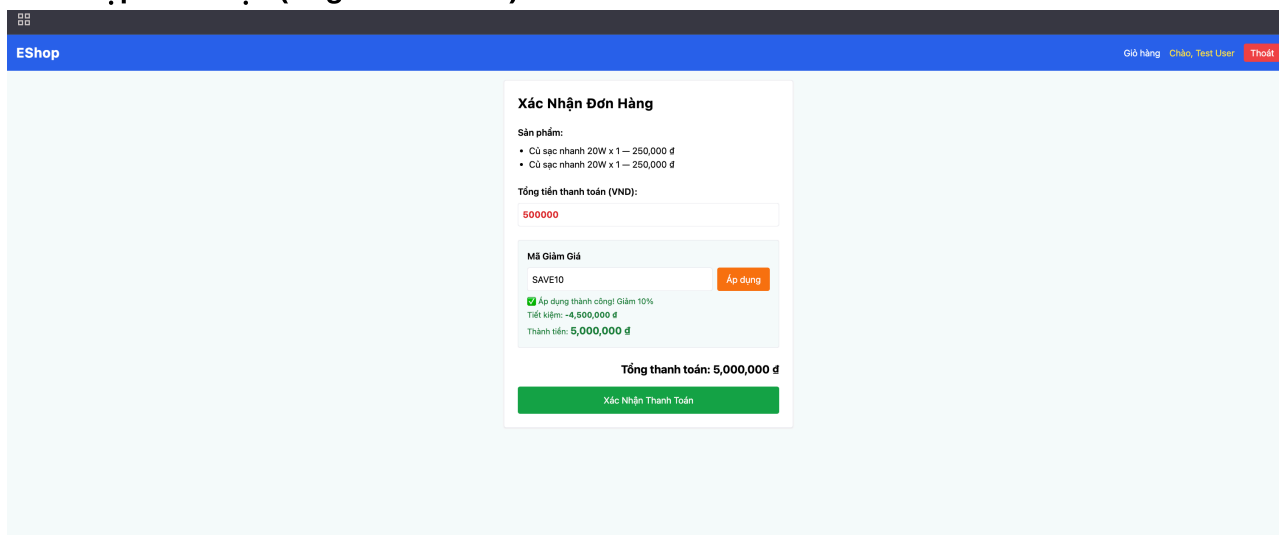
Đăng nhập lại bằng mật khẩu ĐÚNG: HTTP Status = 403 - Response: { error: 'Tài khoản đã bị khóa. Vui lòng thử lại sau.' }

=== KẾT THÚC KIỂM THỬ ===
• (base) HB4305 ~/KhoChua/BH/Năm3/HK3/Kiểm thử phần mềm/HW02 % node scratch_test_race.js
```

Pool B: FR-09: Mã Giảm Giá (Coupon)

BUG-FR09-01: Lỗi tính toán sai số tiền được giảm cho coupon loại phần trăm (percent)

- **Mô tả lỗi:** Khi áp dụng coupon giảm giá theo tỷ lệ phần trăm (percent), backend tính toán sai công thức chiết khấu dẫn đến việc số tiền giảm bị âm (ví dụ: giảm **-4,500,000 đ** cho đơn hàng **500,000 đ** với mã **SAVE10** giảm 10%) và tổng tiền thanh toán cuối cùng bị tăng vọt (lên **5,000,000 đ**).
- **Các bước tái hiện (Steps to Reproduce):**
 1. Đăng nhập vào hệ thống bằng tài khoản khách hàng hợp lệ (ví dụ: **test@eshop.com**).
 2. Đi tới màn hình **Checkout** (hoặc thêm sản phẩm vào giỏ hàng rồi tới trang thanh toán).
 3. Tại trường **"Tổng tiền thanh toán (VND)"**, điền giá trị **500000**.
 4. Tại ô nhập **"Mã Giảm Giá"**, điền mã **SAVE10**.
 5. Nhấn nút **"Áp dụng"**.
 6. Quan sát số tiền giảm giá và tổng tiền thanh toán hiển thị trên màn hình.
- **Kết quả mong đợi (Expected Output):**
 - Hệ thống áp dụng coupon thành công.
 - Hiển thị số tiền tiết kiệm: **50,000 đ**.
 - Hiển thị tổng thanh toán sau giảm giá: **450,000 đ**.
- **Kết quả thực tế (Actual Output):**
 - Hệ thống báo áp dụng thành công nhưng hiển thị số tiền tiết kiệm bị âm: **-4,500,000 đ**.
 - Tổng thanh toán hiển thị bị tăng vọt lên: **5,000,000 đ**.
- **Đường dẫn GitHub Issue:** [GitHub Issue #8](#)
- **Ảnh chụp minh họa (Bug Screenshot):**



BUG-FR09-02: So sánh sai biên tối thiểu khiến đơn hàng bằng đúng ngưỡng tối thiểu bị từ chối

- **Mô tả lỗi:** Theo đặc tả yêu cầu, coupon chỉ được áp dụng khi đơn hàng có tổng trị giá tối thiểu từ **min_order_amount** trở lên (tức là $\geq$). Tuy nhiên, khi giá trị đơn hàng bằng đúng ngưỡng tối thiểu (ví dụ **300,000 đ** đối với mã **SAVE10**), hệ thống vẫn từ chối áp dụng và trả về lỗi không đủ điều kiện đơn hàng tối thiểu.
- **Các bước tái hiện (Steps to Reproduce):**
 1. Mở màn hình **Checkout** của ứng dụng Web.

2. Tại ô "**Tổng tiền thanh toán (VND)**", nhập giá trị **300000** (bằng đúng ngưỡng tối thiểu của mã **SAVE10**).
3. Nhập mã **SAVE10** vào ô "**Mã Giảm Giá**".
4. Nhấn nút "**Áp dụng**".

- **Kết quả mong đợi (Expected Output):**

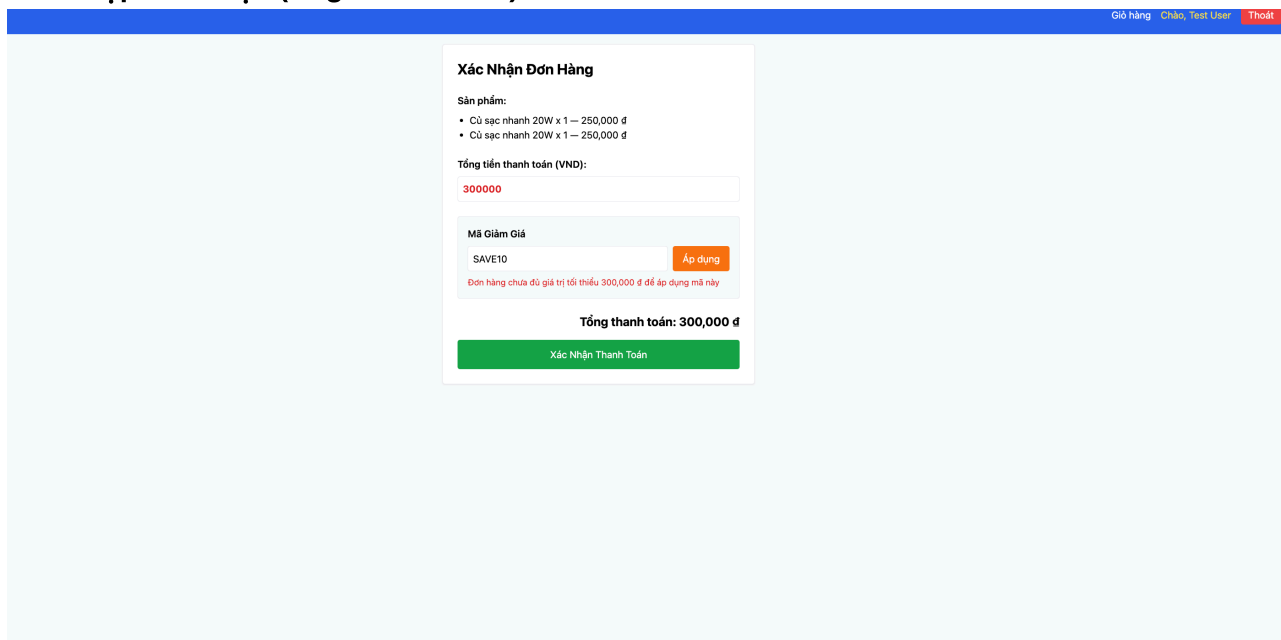
- Hệ thống áp dụng coupon thành công, không báo lỗi.

- **Kết quả thực tế (Actual Output):**

- Hệ thống từ chối áp dụng và hiển thị thông báo lỗi màu đỏ: "**Đơn hàng chưa đủ giá trị tối thiểu 300,000 đ để áp dụng mã này**".

- **Đường dẫn GitHub Issue:** [GitHub Issue #9](#)

- **Ảnh chụp minh họa (Bug Screenshot):**



BUG-FR09-03: Lỗi hỏng API kiểm tra mã giảm giá (/api/apply-coupon) không xác thực Token JWT

- **Mô tả lỗi:** API **/api/apply-coupon** vẫn trả kết quả tính toán coupon thành công khi request không có JWT hợp lệ. Người dùng chưa đăng nhập (hoặc đã đăng xuất) vẫn có thể gửi yêu cầu và nhận thông tin giảm giá, trái với điều kiện C4 của đặc tả.

- **Các bước tái hiện (Steps to Reproduce):**

1. Không tiến hành đăng nhập tài khoản (hoặc đăng xuất khỏi hệ thống).
2. Truy cập trực tiếp trang **Checkout** (**/checkout**).
3. Nhập giá trị **500000** vào ô "**Tổng tiền thanh toán (VND)**".
4. Nhập mã **SAVE10** vào ô "**Mã Giảm Giá**" và nhấn "**Áp dụng**".

- **Kết quả mong đợi (Expected Output):**

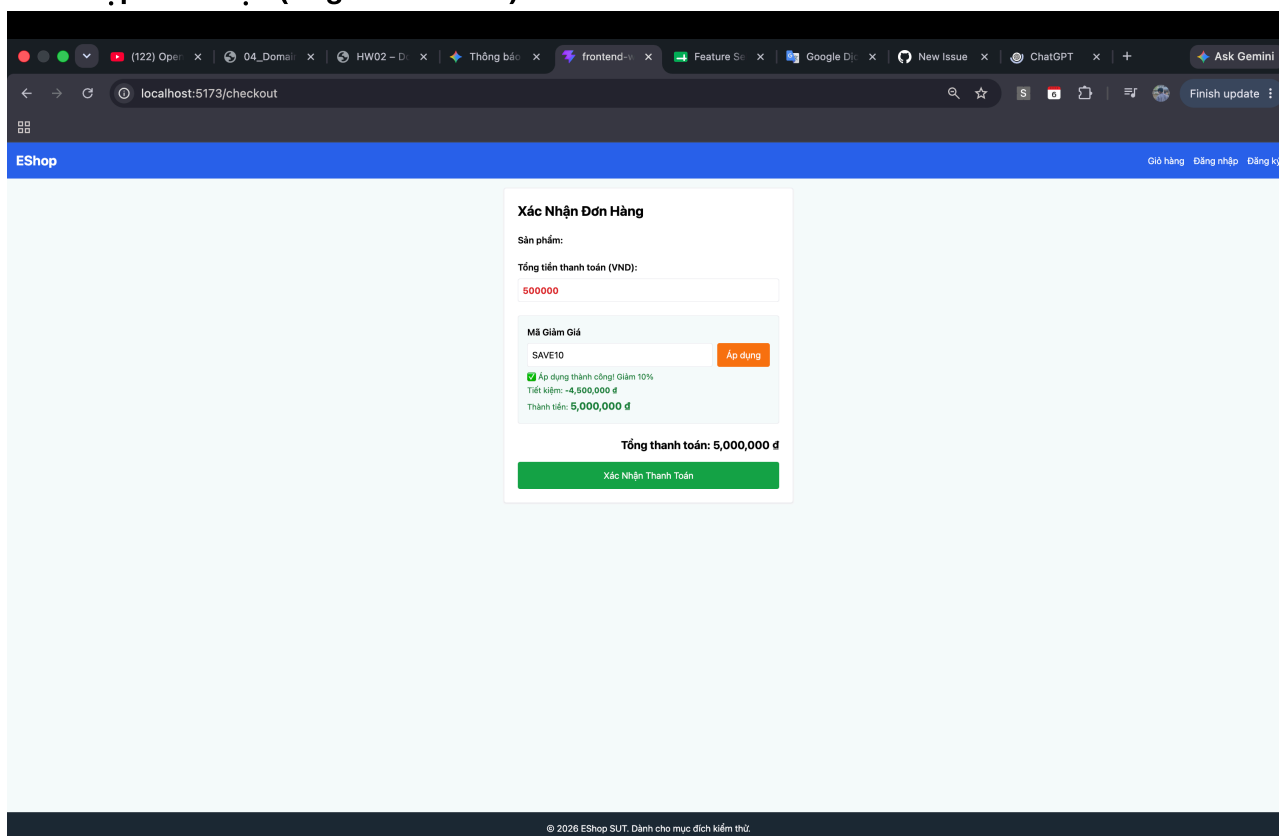
- Hệ thống chặn hành động và thông báo yêu cầu người dùng đăng nhập (hoặc trả về mã lỗi **401 Unauthorized / 403 Forbidden**).

- **Kết quả thực tế (Actual Output):**

- Giao diện vẫn gửi yêu cầu thành công (không kèm Authorization header) và hiển thị kết quả tính toán giảm giá của coupon bình thường.

- **Đường dẫn GitHub Issue:** [GitHub Issue #10](#)

- Ảnh chụp minh họa (Bug Screenshot):



BUG-FR09-04: Hệ thống cho phép giả mạo user_id (ID Spoofing) hoặc bỏ trống user_id khi áp dụng mã giảm giá

- Mô tả lỗi:** API `/api/apply-coupon` vẫn áp dụng coupon thành công khi `user_id` trong request body không khớp với người dùng đang đăng nhập, hoặc khi thiếu `user_id`. Từ góc nhìn hộp đen, API chưa ràng buộc chặt điều kiện sử dụng coupon với JWT hợp lệ của chính người dùng.
- Các bước tái hiện (Steps to Reproduce):**
 - Chạy file script tự động `scratch_test_bug_fr09_04.js` bằng cách chạy lệnh sau trong terminal tại thư mục gốc của dự án:

```
node scratch_test_bug_fr09_04.js
```

- Quan sát kết quả phản hồi in ra trên màn hình terminal của cả 2 kịch bản:
 - Trường hợp 1 (Bỏ trống user_id):** Gửi yêu cầu không có `user_id`.
 - Trường hợp 2 (Giả mạo user_id):** Đăng nhập User A nhưng truyền `user_id` của User B vào request body.
- Kết quả mong đợi (Expected Output):**
 - Hệ thống từ chối áp dụng mã giảm giá, yêu cầu xác thực khớp ID (trả về lỗi **403 Forbidden** hoặc **400 Bad Request**).
- Kết quả thực tế (Actual Output):**
 - Hệ thống phản hồi **200 OK** và áp dụng coupon thành công.
- Đường dẫn GitHub Issue:** [GitHub Issue #11](#)

- Ảnh chụp minh họa (Bug Screenshot):

```
const runTest = async () => {
  console.log("=== KHỞI CHẠY KIỂM THỬ BUG-FR09-04 (ID SPOOFING & EMPTY USER_ID) ===");

  // 1. Đăng nhập để lấy token của User chính chủ (test@eshop.com)
  console.log("Vui lòng nhập tài khoản test@eshop.com để lấy JWT Token...");
  const loginRes = await fetch("http://localhost:3000/api/login", {
    method: "POST",
    headers: { "Content-Type": "application/json" },
    body: JSON.stringify({ email: "test@eshop.com", password: "Test1234!" }),
  });

  if (!loginRes.ok) {
    console.error("Đăng nhập thất bại! Hãy chắc chắn server backend đang chạy.");
    return;
  }

  const loginData = await loginRes.json();
  const token = loginData.token;
  const realUserId = loginData.user_id;
  console.log("-> Đăng nhập thành công. ID người dùng thực tế: $(realUserId)");

  // ---
  // TRƯỜNG HỢP 1: Bỏ trống user_id trong request body
  // ---
  console.log("=====");
  console.log("TRƯỜNG HỢP 1: Bỏ trống user_id (không gửi kèm user_id)");
  console.log("Gửi request POST tới /api/apply-coupon (không có JWT Token)...");

  const resCase1 = await fetch("http://localhost:3000/api/apply-coupon", {
    method: "POST",
    headers: { "Content-Type": "application/json" },
    body: JSON.stringify({
      code: "SAVE10%",
      total_amount: 500000
      // Bỏ trống user_id
    }),
  });

  console.log("HTTP Status: $(resCase1.status)");
  const dataCase1 = await resCase1.json();
  console.log("Response:", dataCase1);

  if (resCase1.ok && dataCase1.success) {
    console.log("🔴 [BUG PHÁT HIỆN]: Hệ thống vẫn cho phép áp dụng mã giảm giá thành công mà không cần user_id (Bypass kiểm tra lượt dùng)!");
  } else {
    console.log("🟢 [PASS]: Hệ thống đã chặn thành công khi thiếu user_id.");
  }

  // ---
  // TRƯỜNG HỢP 2: Giả mạo user_id (ID Spoofing)
  // ---
  console.log("=====");
  console.log("TRƯỜNG HỢP 2: Giả mạo user_id (ID Spoofing)");
  const spoofedUserId = realUserId + 999; // Giả mạo ID khác
  console.log("Gửi request POST tới /api/apply-coupon với Token của User ID: $(realUserId) nhưng truyền user_id trong body: $(spoofedUserId)...");

  const resCase2 = await fetch("http://localhost:3000/api/apply-coupon", {
    method: "POST",
    headers: {
      "Content-Type": "application/json",
      "Authorization": "Bearer $(token)"
    },
    body: JSON.stringify({
      code: "SAVE10%",
      total_amount: 500000,
      user_id: spoofedUserId // ID giả mạo
    }),
  });

  console.log("HTTP Status: $(resCase2.status)");
  const dataCase2 = await resCase2.json();
  console.log("Response:", dataCase2);

  if (resCase2.status === 200 && dataCase2.success) {
    console.log("🔴 [BUG PHÁT HIỆN]: Backend không đối chiếu user_id trong body với token JWT, cho phép giả mạo ID người khác áp dụng coupon!");
  } else {
    console.log("🟢 [PASS]: Hệ thống đã chặn thành công request giả mạo ID (Trả về 403 hoặc 400).");
  }

  console.log("\n=== KẾT THÚC KIỂM THỬ ===");
}

runTest().catch((err) => console.error("Lỗi khi chạy script:", err));
```

(base) HB4305 ~/KhoChua/ĐH/Năm3/HK3/Kiểm thử phần mềm/HW02 % node scratch_test_bug_fr09_04.js
 === KHỞI CHẠY KIỂM THỬ BUG-FR09-04 (ID SPOOFING & EMPTY USER_ID) ===

1. Đăng nhập tài khoản test@eshop.com để lấy JWT Token...
 -> Đăng nhập thành công. ID người dùng thực tế: 2

=====
 TRƯỜNG HỢP 1: Bỏ trống user_id (không gửi kèm user_id)
 Gửi request POST tới /api/apply-coupon (không có JWT Token)...
 HTTP Status: 200
 Response: {
 success: true,
 coupon_id: 1,
 discount_amount: -450000,
 final_amount: 500000,
 message: 'Áp dụng thành công! Giảm 10%'
 }
 🔴 [BUG PHÁT HIỆN]: Hệ thống vẫn cho phép áp dụng mã giảm giá thành công mà không cần user_id (Bypass kiểm tra lượt dùng)!

=====
 TRƯỜNG HỢP 2: Giả mạo user_id (ID Spoofing)
 Gửi request POST tới /api/apply-coupon với Token của User ID: 2 nhưng truyền user_id trong body: 1001...
 HTTP Status: 200
 Response: {
 success: true,
 coupon_id: 1,
 discount_amount: -450000,
 final_amount: 500000,
 message: 'Áp dụng thành công! Giảm 10%'
 }
 🔴 [BUG PHÁT HIỆN]: Backend không đối chiếu user_id trong body với token JWT, cho phép giả mạo ID người khác áp dụng coupon!

=== KẾT THÚC KIỂM THỬ ===
 (base) HB4305 ~/KhoChua/ĐH/Năm3/HK3/Kiểm thử phần mềm/HW02 %

BUG-FR09-05: Lỗi hỏng Checkout Bypass - API thanh toán (/api/checkout) không xác thực lại các điều kiện mã giảm giá

- Mô tả lỗi:** API `/api/checkout` vẫn tạo đơn thành công với `total_amount` do client gửi lên sau khi người dùng sửa tổng tiền/giỏ hàng, thay vì từ chối hoặc tự tính lại theo giỏ hàng và điều kiện

coupon hiện tại như đặc tả FR-08/FR-09. Giao diện Checkout cũng cho phép người dùng sửa trực tiếp ô số tiền thanh toán.

- **Các bước tái hiện (Steps to Reproduce):**

1. Đăng nhập hệ thống, thêm sản phẩm vào giỏ hàng và đi tới trang **Checkout**.
2. Tại ô nhập liệu "**Tổng tiền thanh toán (VND)**", xóa giá trị cũ của giỏ hàng và nhập vào một con số cực nhỏ tùy ý (ví dụ: **50000** đ).
3. Nhấn nút "**Xác Nhận Thanh Toán**".
4. Kiểm tra thông báo kết quả và giá trị đơn hàng mới tạo trong trang Lịch sử đơn hàng.

- **Kết quả mong đợi (Expected Output):**

- Hệ thống từ chối thanh toán do số tiền gửi lên không khớp với tổng tiền thực tế của giỏ hàng (hoặc không đủ điều kiện tối thiểu của mã giảm giá).

- **Kết quả thực tế (Actual Output):**

- Giao diện báo thanh toán thành công và đơn hàng mới được tạo trên hệ thống với đúng giá trị **50,000** đ mà không gặp lỗi validation.

- **Đường dẫn GitHub Issue:** [GitHub Issue #12](#)

- **Ảnh chụp minh họa (Bug Screenshot):**

The screenshot displays the EShop checkout interface. At the top, a blue navigation bar contains the EShop logo, links for 'Giỏ hàng', 'Chào, Test User', and a 'Thoát' button. The main content area features a light blue background. A white modal box titled 'Xác Nhận Đơn Hàng' is centered. It lists the product 'Bàn phím cơ Keychron Q1 x 1 — 4,000,000 đ'. Below this, the 'Tổng tiền thanh toán (VND):' is shown with a text input field containing '50000'. A section for 'Mã Giảm Giá' includes a text input field with the placeholder 'NHẬP MÃ GIẢM GIÁ...' and an 'Áp dụng' button. The modal also displays 'Tổng thanh toán: 50,000 đ' and a green 'Xác Nhận Thanh Toán' button. Below the modal, a large green banner reads 'Thanh toán thành công!' in bold green text. Underneath the banner, the text 'Cảm ơn bạn đã mua sắm tại EShop.' is displayed, followed by a blue link 'Quay lại trang chủ'.

BUG-FR09-06: Lỗi xử lý thông điệp phản hồi không khớp cho dữ liệu đầu vào không hợp lệ (số tiền âm hoặc sai kiểu dữ liệu)

- **Mô tả lỗi:** Khi người dùng gửi yêu cầu áp dụng mã giảm giá với các dữ liệu sai định dạng nghiêm trọng ở biến `total_amount` như số tiền âm (`-50000`) hoặc chuỗi ký tự chữ không hợp lệ, hệ thống phản hồi lỗi logic nghiệp vụ gây hiểu lầm là đơn hàng không đủ ngưỡng tối thiểu, thay vì phản hồi lỗi định dạng dữ liệu đầu vào.
- **Các bước tái hiện (Steps to Reproduce):**
 1. Mở trang **Checkout** của ứng dụng Web.
 2. Tại ô "**Tổng tiền thanh toán (VND)**", điền giá trị âm `-50000` (hoặc nhập chuỗi ký tự chữ không phải số).
 3. Nhập mã giảm giá `SAVE10` vào ô "**Mã Giảm Giá**".
 4. Nhấn nút "**Áp dụng**".
- **Kết quả mong đợi (Expected Output):**
 - Hệ thống báo lỗi định dạng dữ liệu đầu vào hoặc tổng số tiền đơn hàng không hợp lệ.
- **Kết quả thực tế (Actual Output):**
 - Hệ thống báo lỗi nghiệp vụ không liên quan: "**Đơn hàng chưa đủ giá trị tối thiểu 300,000 đ để áp dụng mã này**".
- **Đường dẫn GitHub Issue:** [GitHub Issue #13](#)

- Ảnh chụp minh họa (Bug Screenshot):

The screenshot shows a checkout interface with the following elements:

- Xác Nhận Đơn Hàng** (Confirm Order)
- Sản phẩm:** (Product)
- Tổng tiền thanh toán (VND):** (Total payment (VND))
- A text box containing **-50000**
- Mã Giảm Giá** (Discount Code)
- A text box containing **SAVE10**
- An orange button labeled **Áp dụng** (Apply)
- A red error message: **Đơn hàng chưa đủ giá trị tối thiểu 300,000 đ để áp dụng mã này** (Order does not meet the minimum value of 300,000 VND to apply this code)
- Tổng thanh toán: -50,000 đ** (Total payment: -50,000 VND)
- A green button labeled **Xác Nhận Thanh Toán** (Confirm Payment)

BUG-FR09-07: Lỗi hỏng Race Condition (Double Apply) cho phép áp dụng mã giới hạn 1 lần nhiều lần

- Mô tả lỗi:** Khi gửi đồng thời nhiều request áp dụng mã giảm giá qua endpoint công khai **POST /api/apply-coupon** trong cùng 1 mili giây, hệ thống chấp nhận nhiều request thành công cho cùng một mã giới hạn 1 lần. Hành vi này cho phép người dùng vượt qua ràng buộc số lần sử dụng tối đa theo đặc tả.
- Các bước tái hiện (Steps to Reproduce):**
 - Do Race Condition diễn ra trong mili giây nên cần thực hiện qua script tự động gửi request API đồng thời:
 - 1. Sử dụng script kiểm thử **scratch_test_coupon.js** (hoặc các công cụ gửi request đồng thời như JMeter/k6).
 - 2. Thực hiện đăng nhập và lấy JWT token hợp lệ của một tài khoản chưa từng sử dụng coupon **SAVE10** (giới hạn 1 lần dùng).

3. Gửi đồng thời 2 request **POST /api/apply-coupon** trong cùng 1 mili giây với body hợp lệ: `{"code":"SAVE10","total_amount":500000,"user_id":1}`.
4. Kiểm tra mã trạng thái HTTP và response body trả về của cả 2 request.

- **Kết quả mong đợi (Expected Output):**

- Chỉ có duy nhất 1 request thành công (**200 OK**). Request còn lại phải trả về mã lỗi (**400 Bad Request** hoặc **500 Internal Server Error**).

- **Kết quả thực tế (Actual Output):**

- Cả 2 request gửi đồng thời đều thành công (**200 OK**), cùng trả về kết quả áp dụng mã giảm giá thành công cho mã giới hạn 1 lần.

- **Đường dẫn GitHub Issue:** [GitHub Issue #14](#)

- **Ảnh chụp minh họa (Bug Screenshot):**

```
// =====
// TC14: Race Condition - Gửi 2 request checkout đồng thời
// =====
console.log("\n--- TC14: Race Condition khi ghi nhận sử dụng mã giảm giá ---");
const cleanEmail2 = `user_tc14_${Date.now()}@eshop.com`;
await fetch('http://localhost:3000/api/register', {
  method: 'POST',
  headers: { 'Content-Type': 'application/json' },
  body: JSON.stringify({ name: 'TC14 User', email: cleanEmail2, password: 'Password123!' })
});
const loginCleanRes2 = await fetch('http://localhost:3000/api/login', {
  method: 'POST',
  headers: { 'Content-Type': 'application/json' },
  body: JSON.stringify({ email: cleanEmail2, password: 'Password123!' })
});
const loginCleanData2 = await loginCleanRes2.json();
const cleanToken2 = loginCleanData2.token;

console.log("Gửi song song 2 request ghi nhận sử dụng mã SAVE10...");
const usageReq = async (id) => {
  const res = await fetch('http://localhost:3000/api/coupon-usage', {
    method: 'POST',
    headers: {
      'Content-Type': 'application/json',
      'Authorization': `Bearer ${cleanToken2}`
    },
    body: JSON.stringify({ coupon_id: 1 })
  });
  console.log(`Request ${id}: Status = ${res.status}, Body =`, await res.json());
};
await Promise.all([usageReq(1), usageReq(2)]);
```

Response can 2: { error: 'Bạn đã sử dụng mã này 1 lần (đã đạt giới hạn)' }

```
--- TC14: Race Condition khi ghi nhận sử dụng mã giảm giá ---
Gửi song song 2 request ghi nhận sử dụng mã SAVE10...
Request 1: Status = 200, Body = { message: 'Usage recorded' }
Request 2: Status = 200, Body = { message: 'Usage recorded' }
```

TC15: Checkout Bypass

Pool C: FR-17: Quản lý Mã Giảm Giá (Coupon CRUD)

BUG-FR17-01: API Admin tạo coupon không kiểm tra role Admin

- **Mô tả lỗi:** Theo FR-12, các API Admin hoặc API có tác động dữ liệu phải yêu cầu token hợp lệ và role Admin. Tuy nhiên endpoint tạo coupon chấp nhận token của user thường và tạo bản ghi coupon mới.
- **Các bước tái hiện (Steps to Reproduce):**

1. Đăng nhập bằng tài khoản user thường `test@eshop.com` để lấy token hợp lệ.
 2. Do giao diện Admin chặn user thường ở màn hình đăng nhập, gửi trực tiếp request **POST** `/api/admin/coupons` với header **Authorization: Bearer <user_token>**.
 3. Dùng body coupon hợp lệ, ví dụ `code = "TET2025", type = "percent", discount_value = 15, expired_at = "2027-01-31", min_order_amount = 200000, max_uses_per_user = 1`.
 4. Quan sát response.
- **Kết quả mong đợi (Expected Output):** Server từ chối request với lỗi không đủ quyền (**403 Forbidden** hoặc lỗi phân quyền tương đương) và không tạo coupon.
 - **Kết quả thực tế (Actual Output):** Server trả HTTP 200 với body `{"message": "Coupon created", "id": 5}`.
 - **Bằng chứng thực thi:** Test case **TC05**.
 - **Đường dẫn GitHub Issue:** [GitHub Issue #15](#)
 - **Ảnh chụp minh họa (Bug Screenshot):**

```
const runTest = async () => {
  console.log("=== KHỞI CHẠY KIỂM THỬ BUG-FR17-01 (ROLE ADMIN BYPASS ON CREATING COUPON) ===");

  // 1. Đăng nhập tài khoản user thường (test@eshop.com) để lấy JWT Token
  console.log("\n1. Đăng nhập tài khoản user thường test@eshop.com để lấy JWT Token...");
  const loginRes = await fetch("http://localhost:3000/api/login", {
    method: "POST",
    headers: { "Content-Type": "application/json" },
    body: JSON.stringify({ email: "test@eshop.com", password: "Test1234!" }),
  });

  if (!loginRes.ok) {
    console.error("❌ Đăng nhập tài khoản user thường thất bại! Hãy chắc chắn server backend đang chạy.");
    return;
  }

  const loginData = await loginRes.json();
  const token = loginData.token;
  console.log("→ Đăng nhập thành công. Đang nắm giữ token của user thường.");

  // 2. Gửi yêu cầu tạo Coupon tới API admin bằng token của user thường
  console.log("\n2. Gửi request POST tới /api/admin/coupons bằng token của user thường...");
  const couponData = {
    code: "TET2025_BYPASS",
    type: "percent",
    discount_value: 15,
    expired_at: "2027-01-31",
    min_order_amount: 200000,
    max_uses_per_user: 1
  };

  const res = await fetch("http://localhost:3000/api/admin/coupons", {
    method: "POST",
    headers: {
      "Content-Type": "application/json",
      "Authorization": `Bearer ${token}`
    },
    body: JSON.stringify(couponData),
  });

  console.log(`HTTP Status nhận được: ${res.status}`);
  const data = await res.json();
  console.log("Response từ server:", data);

  // 3. Đánh giá kết quả
  console.log("\n3. Đánh giá kết quả kiểm thử:");
  if (res.status === 200 || res.status === 201) {
    console.log("🔴 [BUG PHÁT HIỆN]: Server cho phép user thường tạo coupon thành công (HTTP 200/201)!");
    console.log("API /api/admin/coupons không kiểm tra role Admin của token.");
  } else if (res.status === 403 || res.status === 401) {
    console.log("🟢 [PASS]: Server từ chối request của user thường một cách chính xác (trả về 403 Forbidden hoặc 401 Unauthorized).");
  } else {
    console.log("🟡 [KẾT QUẢ KHÁC]: Nhận mã HTTP ${res.status}. Vui lòng kiểm tra lại logic backend.");
  }

  console.log("\n=== KẾT THÚC KIỂM THỬ ===");
};

runTest().catch((err) => console.error("Lỗi khi chạy script:", err));
```

```

● (base) HB4305 ~/KhoChua/ĐH/Năm3/HK3/Kiểm thử phần mềm/HW02 % node scratch_test_bug_fr17_01.js
=== KHỞI CHẠY KIỂM THỬ BUG-FR17-01 (ROLE ADMIN BYPASS ON CREATING COUPON) ===

1. Đăng nhập tài khoản user thường test@eshop.com để lấy JWT Token...
   → Đăng nhập thành công. Đang nắm giữ token của user thường.

2. Gửi request POST tới /api/admin/coupons bằng token của user thường...
   HTTP Status nhận được: 200
   Response từ server: { message: 'Coupon created', id: 5 }

3. Đánh giá kết quả kiểm thử:
   ● [BUG PHÁT HIỆN]: Server cho phép user thường tạo coupon thành công (HTTP 200/201)!
     API /api/admin/coupons không kiểm tra role Admin của token.

=== KẾT THÚC KIỂM THỬ ===
○ (base) HB4305 ~/KhoChua/ĐH/Năm3/HK3/Kiểm thử phần mềm/HW02 %

```

BUG-FR17-02: API tạo coupon không validate trường code bắt buộc

- **Mô tả lỗi:** Endpoint `POST /api/admin/coupons` không chặn `code` rỗng. Vì vậy hệ thống vẫn tạo coupon mới dù mã giảm giá không có giá trị định danh hợp lệ.
- **Các bước tái hiện (Steps to Reproduce):**
 1. Đăng nhập bằng tài khoản Admin `admin@eshop.com`.
 2. Vì form UI có thuộc tính `required` cho ô mã coupon, gửi trực tiếp request `POST /api/admin/coupons` để kiểm tra validation phía backend.
 3. Dùng body có `code = ""`, các trường còn lại hợp lệ.
 4. Quan sát status code và body response.
- **Kết quả mong đợi (Expected Output):** Server trả lỗi validation, không tạo coupon mới, và thông báo `code` là trường bắt buộc.
- **Kết quả thực tế (Actual Output):** Server trả HTTP 200 với body `{"message": "Coupon created", "id": 5}`.
- **Bảng chứng thực thi:** Test case `TC06` và `TC-BVA-01`.
- **Đường dẫn GitHub Issue:** [GitHub Issue #16](#)
- **Ảnh chụp minh họa (Bug Screenshot):**

```

❯ (base) HB4385 ~\KhoChua\BH\Nam3\HK3\Kiếm thử phần mềm\HW02 % curl -X POST http://localhost:3000/api/login \
  -H "Content-Type: application/json" \
  -d '{"email": "admin@eshop.com", "password": "Admin123!@!"}'

{"message": "Login successful", "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZiZCmSwicm9mZSI6ImFkbWUiOiwiZWFiOj0xNzgxNDM1NzQxOT0uPm5ARA1XS2MegMEkSeonvqNpYUUpI8H0y6pSinas", "user": {"id": 1, "name": "Admin User", "email": "admin@eshop.com", "password": "Admin123!", "role": "admin", "login_attempts": 0, "locked_until": null, "reset_token": null, "shipping_address": null, "phone": null}}

❯ (base) HB4385 ~\KhoChua\BH\Nam3\HK3\Kiếm thử phần mềm\HW02 % curl -i -X POST http://localhost:3000/api/admin/coupons \
  -H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZiZCmSwicm9mZSI6ImFkbWUiOiwiZWFiOj0xNzgxNDM1NzQxOT0uPm5ARA1XS2MegMEkSeonvqNpYUUpI8H0y6pSinas" \
  -H "Content-Type: application/json" \
  -d '{"code": "", "type": "percent", "discount_value": 15, "min_order_amount": 200000, "expired_at": "2027-01-31", "max_uses_per_user": 1}'

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 35
ETag: W/"23-Nq1988hmlJ36XlKa2ubTQwdshY8"
Date: Tue, 07 Jul 2026 14:40:44 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message": "Coupon created", "id": 6}

```

BUG-FR17-03: API tạo coupon không validate miền giá trị type

- **Mô tả lỗi:** Endpoint tạo coupon không kiểm tra **type** thuộc tập hợp hợp lệ **percent** hoặc **fixed**, đồng thời vẫn chấp nhận request thiếu **type**.
- **Các bước tái hiện (Steps to Reproduce):**
 1. Đăng nhập bằng tài khoản Admin.
 2. Vì giao diện Admin chỉ cho chọn **percent** hoặc **fixed**, gửi trực tiếp request **POST /api/admin/coupons** để kiểm tra validation phía backend.
 3. Gửi một request với **type = "cashback"**.

- ```
(base) HB4305 ~/KhoChua/BH/Nam3/HK3/Kiem_thu_phan_mem/HW02 % curl -X POST http://localhost:3000/api/login \
-H "Content-Type: application/json" \
-d '{"email":"admin@eshop.com","password":"Admin123!}"'

{"message":"login successful","token":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImVlc295ZS16ImFkbWUwIiwiaWF0Ij0xNzgzNDk3MjYzZGQyMm47TgAf1fB-eBxN7g-8QvXSGtP9cef9shOKIS7bE","user":{"id":1,"name":"Admin User","email":"admin@eshop.com","password":"Admin123!","role":"admin","login_attempts":0,"locked_until":null,"reset_token":null,"shipping_address":null,"phone":null}}

(base) HB4305 ~/KhoChua/BH/Nam3/HK3/Kiem_thu_phan_mem/HW02 % curl -i -X POST http://localhost:3000/admin/coupons \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImVlc295ZS16ImFkbWUwIiwiaWF0Ij0xNzgzNDk3MjYzZGQyMm47TgAf1fB-eBxN7g-8QvXSGtP9cef9shOKIS7bE" \
-H "Content-Type: application/json" \
-d '{"code":"TET_CASHBACK","type":"cashback","discount_value":15,"min_order_amount":200000,"expired_at":"2027-01-31","max_uses_per_user":1}'

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 35
ETag: W/"23-ac1fV6IM15o9Gskr2mfEF6W5s"
Date: Wed, 08 Jul 2026 07:55:12 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Coupon created","id":18}

(base) HB4305 ~/KhoChua/BH/Nam3/HK3/Kiem_thu_phan_mem/HW02 % curl -i -X POST http://localhost:3000/api/admin/coupons \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImVlc295ZS16ImFkbWUwIiwiaWF0Ij0xNzgzNDk3MjYzZGQyMm47TgAf1fB-eBxN7g-8QvXSGtP9cef9shOKIS7bE" \
-H "Content-Type: application/json" \
-d '{"code":"TET_MISSING_TYPE","discount_value":15,"min_order_amount":200000,"expired_at":"2027-01-31","max_uses_per_user":1}'

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 35
ETag: W/"23-a4P1TIUfMxYUhbJ8GSeRBACfZU"
Date: Wed, 08 Jul 2026 07:55:40 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Coupon created","id":18}

(base) HB4305 ~/KhoChua/BH/Nam3/HK3/Kiem_thu_phan_mem/HW02 %
```

- **Mô tả lỗi:** Endpoint tạo coupon không kiểm tra giá trị giảm là số dương. Hệ thống vẫn tạo coupon khi `discount_value` bằng 0, âm hoặc là chuỗi sai kiểu dữ liệu.
- **Các bước tái hiện (Steps to Reproduce):**
  1. Đăng nhập bằng tài khoản Admin.
  2. Trên tab **Mã Giảm Giá**, nhập một coupon mới với các trường hợp lệ, nhưng đặt **Giá trị** bằng **0**, sau đó bấm **Tạo mã**.
  3. Lặp lại thao tác trên với **Giá trị** bằng **-5**.
  4. Với trường hợp sai kiểu dữ liệu (`discount_value = "abc"`), gửi trực tiếp API vì input số trên UI không cho nhập chữ.
  5. Quan sát coupon có được tạo hay không và response của từng request.
- **Kết quả mong đợi (Expected Output):** Server trả lỗi validation và không tạo coupon vì giá trị giảm phải là số dương hợp lệ.
- **Kết quả thực tế (Actual Output):** Các payload invalid vẫn được tạo coupon thành công với HTTP 200 và body `{"message": "Coupon created", "id": 5}`.
- **Bảng chứng thực thi:** Test case **TC10**, **TC11**, **TC12** và **TC-BVA-03**.
- **Đường dẫn GitHub Issue:** [GitHub Issue #18](#)



- Ảnh chụp minh họa (Bug Screenshot):

```
Keep-Alive: timeout=5
{"error":"Forbidden"}
(base) HB4305 ~/KhoaChua/BH/Nam3/HK3/Kiểm thử phần mềm/HW02 % clear
(base) HB4305 ~/KhoaChua/BH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -X POST http://localhost:3000/api/login \
-H "Content-Type: application/json" \
-d '{"email": "admin@eshop.com", "password": "Admin123!}"'

{"message":"Login successful","token":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwlc295ZSI6ImFkbWwluIiwiaWF0IjoxNzgzNTAwODA2fQ.g3a_u92JpY8pYV06fdjbJ_qb1U6wU3HjKpMiAGUCg","user":{"id":1,"name":"Admin User","email":"admin@eshop.com","password":"Admin123!","role":"admin","login_attempts":0,"locked_until":null,"reset_token":null,"shipping_address":null,"phone":null}}

(base) HB4305 ~/KhoaChua/BH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -i -X POST http://localhost:3000/api/admin/coupons \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwlc295ZSI6ImFkbWwluIiwiaWF0IjoxNzgzNTAwODA2fQ.g3a_u92JpY8pYV06fdjbJ_qb1U6wU3HjKpMiAGUCg" \
-H "Content-Type: application/json" \
-d '{"code": "TET_DISCOUNT_0", "type": "percent", "discount_value": 0, "min_order_amount": 200000, "expired_at": "2027-01-31", "max_uses_per_user": 1}'

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 35
ETag: W/"23-U08e1brEh7P0ZX05+sKxjKs1c"
Date: Wed, 08 Jul 2026 08:54:11 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Coupon created","id":9}

(base) HB4305 ~/KhoaChua/BH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -i -X POST http://localhost:3000/api/admin/coupons \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwlc295ZSI6ImFkbWwluIiwiaWF0IjoxNzgzNTAwODA2fQ.g3a_u92JpY8pYV06fdjbJ_qb1U6wU3HjKpMiAGUCg" \
-H "Content-Type: application/json" \
-d '{"code": "TET_DISCOUNT_NEG", "type": "percent", "discount_value": -5, "min_order_amount": 200000, "expired_at": "2027-01-31", "max_uses_per_user": 1}'

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 36
ETag: W/"24-adW9CBA7gwhIRJB8Yse4xkTPY"
Date: Wed, 08 Jul 2026 08:54:40 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Coupon created","id":10}

(base) HB4305 ~/KhoaChua/BH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -i -X POST http://localhost:3000/api/admin/coupons \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwlc295ZSI6ImFkbWwluIiwiaWF0IjoxNzgzNTAwODA2fQ.g3a_u92JpY8pYV06fdjbJ_qb1U6wU3HjKpMiAGUCg" \
-H "Content-Type: application/json" \
-d '{"code": "TET_DISCOUNT_STR", "type": "percent", "discount_value": "abc", "min_order_amount": 200000, "expired_at": "2027-01-31", "max_uses_per_user": 1}'

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 36
ETag: W/"24-SxsDBHvAP4ZCA14/z8Mnczfakbg"
Date: Wed, 08 Jul 2026 08:55:03 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Coupon created","id":11}

(base) HB4305 ~/KhoaChua/BH/Nam3/HK3/Kiểm thử phần mềm/HW02 %
```

## BUG-FR17-05: API tạo coupon không validate **expired\_at**

- Mô tả lỗi:** Endpoint tạo coupon không kiểm tra ngày hết hạn là trường bắt buộc và có định dạng ngày hợp lệ. Hệ thống vẫn tạo coupon khi thiếu **expired\_at** hoặc truyền giá trị không phải ngày.
- Các bước tái hiện (Steps to Reproduce):**
  - Đăng nhập bằng tài khoản Admin.
  - Vì form UI dùng input ngày bắt buộc, gửi trực tiếp request **POST /api/admin/coupons** để kiểm tra validation phía backend.
  - Gửi một request với body thiếu **expired\_at**.
  - Gửi một request khác với **expired\_at = "not-a-date"**.
  - Quan sát response của từng request.
- Kết quả mong đợi (Expected Output):** Server trả lỗi validation và không tạo coupon vì ngày hết hạn bị thiếu hoặc sai định dạng.
- Kết quả thực tế (Actual Output):** Các payload invalid vẫn được tạo coupon thành công với HTTP 200 và body **{"message":"Coupon created","id":5}**.
- Bằng chứng thực thi:** Test case **TC13** và **TC14**.
- Đường dẫn GitHub Issue:** [GitHub Issue #19](#)



- **Ảnh chụp minh họa (Bug Screenshot):**

```
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiem thu phan mem/HW02 % curl -X POST http://localhost:3000/api/login \
-H "Content-Type: application/json" \
-d '{"email": "admin@eshop.com", "password": "Admin123!"}'

{"message": "Login successful", "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwicm9sZSI6ImFkbWwIiwiaWF0IjoxNzgzNTAzMDc1fQ.N_T8TnYqnvdrk60G2d3gYBdErD1", "user": {"id": 1, "name": "Admin User", "email": "admin@eshop.com", "password": "Admin123!", "role": "admin", "login_attempts": 0, "locked_until": null, "reset_token": null, "shipping_address": null, "phone": null}}

(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiem thu phan mem/HW02 % curl -i -X POST http://localhost:3000/api/admin/coupons \
-d '{"code": "TET_MISSING_DATE", "type": "percent", "discount_value": 15, "min_order_amount": 200000, "max_uses_per_user": 1}'

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 35
ETag: W/"23-Ud55fv6zrzVhIg7PSB5HFfaTsrgQ"
Date: Wed, 08 Jul 2026 09:31:42 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message": "Coupon created", "id": 5}

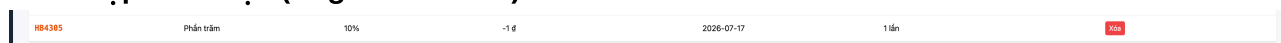
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiem thu phan mem/HW02 % curl -i -X POST http://localhost:3000/api/admin/coupons \
-d '{"code": "TET_INVALID_DATE", "type": "percent", "discount_value": 15, "min_order_amount": 200000, "expired_at": "not-a-date", "max_uses_per_user": 1}'

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 35
ETag: W/"23-NqL988HnU36Xlkq2ubTQmvdshY8"
Date: Wed, 08 Jul 2026 09:32:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message": "Coupon created", "id": 6}
```

## BUG-FR17-06: API tạo coupon không validate **min\_order\_amount**

- **Mô tả lỗi:** Endpoint tạo coupon không kiểm tra giá trị đơn tối thiểu phải là số không âm. Hệ thống vẫn tạo coupon khi **min\_order\_amount** âm hoặc sai kiểu dữ liệu.
- **Các bước tái hiện (Steps to Reproduce):**
  1. Đăng nhập bằng tài khoản Admin.
  2. Trên tab **Mã Giảm Giá**, nhập một coupon mới với các trường hợp lệ, nhưng đặt **Đơn tối thiểu** bằng **-1**, sau đó bấm **Tạo mã**.
  3. Với trường hợp sai kiểu dữ liệu (**min\_order\_amount** = **"two hundred"**), gửi trực tiếp API vì input số trên UI không cho nhập chữ.
  4. Quan sát coupon có được tạo hay không và response của từng request.
- **Kết quả mong đợi (Expected Output):** Server trả lỗi validation và không tạo coupon vì giá trị đơn tối thiểu không hợp lệ.
- **Kết quả thực tế (Actual Output):** Các payload invalid vẫn được tạo coupon thành công với HTTP 200 và body **{"message": "Coupon created", "id": 5}**.
- **Bảng chứng thực thi:** Test case **TC15**, **TC16** và **TC-BVA-05**.
- **Đường dẫn GitHub Issue:** [GitHub Issue #20](#)
- **Ảnh chụp minh họa (Bug Screenshot):**



```
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -X POST http://localhost:3000/api/login \
-H "Content-Type: application/json" \
-d '{"email": "admin@eshop.com", "password": "Admin123!"}'

{"message":"Login successful","token":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6Im5wcm9sZSI6ImFkbWluIiwiaWF0IjoxNzgzNTA0DE1fQ.hhm_8A-CwyjEUyu_CqyCf5G8MmD8sV8AJK0YhZJWQ5s","user":{"id":1,"name":"Admin User","email":"admin@eshop.com","password":"Admin123!","role":"admin","login_attempts":0,"locked_until":null,"reset_token":null,"shipping_address":null,"phone":null}}
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -i -X POST http://localhost:3000/api/admin/coupons \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6Im5wcm9sZSI6ImFkbWluIiwiaWF0IjoxNzgzNTA0DE1fQ.hhm_8A-CwyjEUyu_CqyCf5G8MmD8sV8AJK0YhZJWQ5s" \
-H "Content-Type: application/json" \
-d '{"code": "TET_INVALID_DATE", "type": "percent", "discount_value": 15, "min_order_amount": 200000, "expired_at": "not-a-date", "max_uses_per_user": 1}'

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 35
ETag: W/"23-Nq1988HnU36XlKq2ubTQwvdsY8"
Date: Wed, 08 Jul 2026 10:00:36 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Coupon created","id":6}
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 %
```

## BUG-FR17-07: API tạo coupon không validate `max_uses_per_user`

- **Mô tả lỗi:** Endpoint tạo coupon không kiểm tra số lượt dùng tối đa mỗi người phải là số nguyên tối thiểu 1. Hệ thống vẫn tạo coupon khi `max_uses_per_user = 0`.
- **Các bước tái hiện (Steps to Reproduce):**
  1. Đăng nhập bằng tài khoản Admin.
  2. Vì form UI đặt `min = 1` cho ô số lần dùng tối đa/người, gửi trực tiếp request `POST /api/admin/coupons` để kiểm tra validation phía backend.
  3. Dùng body có `max_uses_per_user = 0`, các trường còn lại hợp lệ.
  4. Quan sát response.
- **Kết quả mong đợi (Expected Output):** Server trả lỗi validation và không tạo coupon vì số lượt dùng tối đa mỗi user phải tối thiểu 1.
- **Kết quả thực tế (Actual Output):** Payload invalid vẫn được tạo coupon thành công với HTTP 200 và body `{"message": "Coupon created", "id": 5}`.
- **Bảng chứng thực thi:** Test case `TC17` và `TC-BVA-07`.
- **Đường dẫn GitHub Issue:** [GitHub Issue #21](#)
- **Ảnh chụp minh họa (Bug Screenshot):**

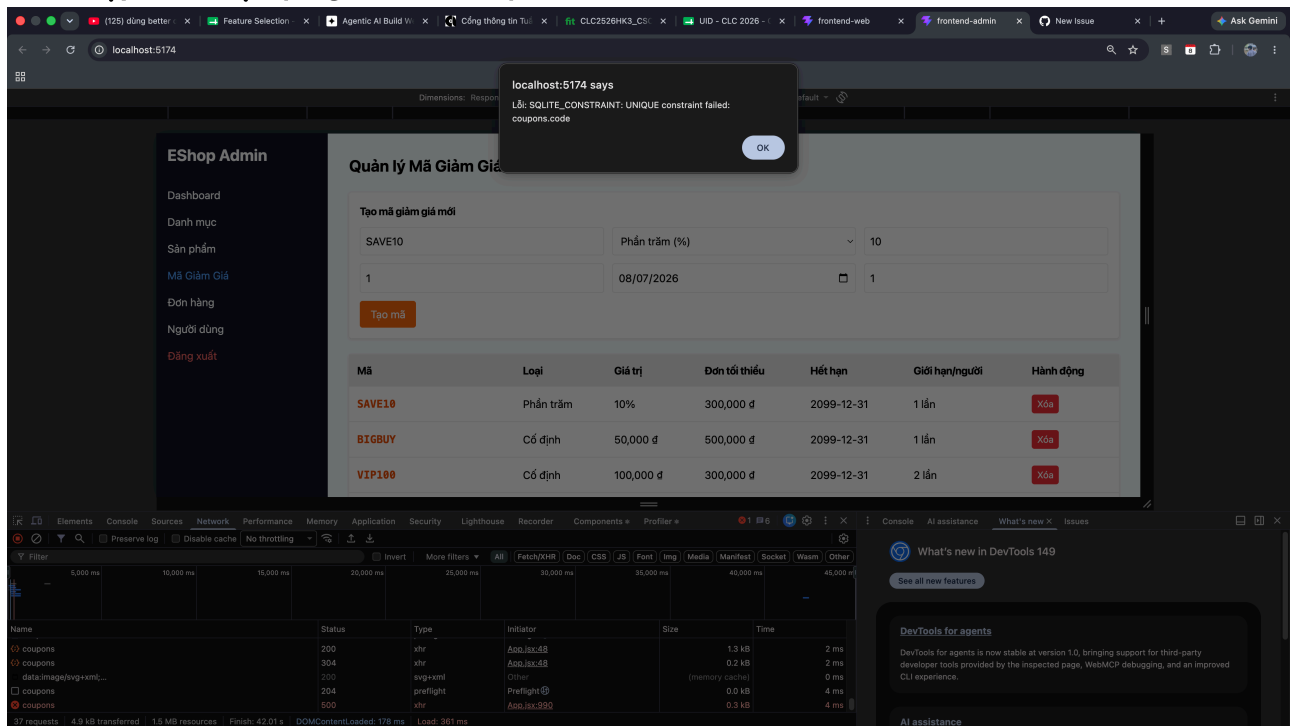
```
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -X POST http://localhost:3000/api/login -H "Content-Type: application/json" -d '{"email": "admin@eshop.com", "password": "Admin123!"}'
{"message":"Login successful","token":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6Im5wcm9sZSI6ImFkbWluIiwiaWF0IjoxNzgzNTA1NjUyYfQ.U14zvBY9HQ_EpyUePBCmqEbj6CKvPzIKU1amHeImxe0","user":{"id":1,"name":"Admin User","email":"admin@eshop.com","password":"Admin123!","role":"admin","login_attempts":0,"locked_until":null,"reset_token":null,"shipping_address":null,"phone":null}}
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -i -X POST http://localhost:3000/api/admin/coupons \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6Im5wcm9sZSI6ImFkbWluIiwiaWF0IjoxNzgzNTA1NjUyYfQ.U14zvBY9HQ_EpyUePBCmqEbj6CKvPzIKU1amHeImxe0" \
-H "Content-Type: application/json" \
-d '{"code": "TET_USES_0", "type": "percent", "discount_value": 15, "min_order_amount": 200000, "expired_at": "2027-01-31", "max_uses_per_user": 0}'

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 35
ETag: W/"23-aCf1v6eIMi5o9Gskr2mfEfG6W5s"
Date: Wed, 08 Jul 2026 10:14:52 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Coupon created","id":7}
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 %
```

## BUG-FR17-08: Tạo coupon trùng mã trả lỗi 500 và lỗi SQLite

- **Mô tả lỗi:** Ràng buộc unique của `code` có tồn tại, nhưng khi tạo coupon trùng mã hệ thống để lỗi tăng cơ sở dữ liệu trôi thẳng ra response dưới dạng HTTP 500, thay vì trả lỗi nghiệp vụ thân thiện như mã giảm giá đã tồn tại.
- **Các bước tái hiện (Steps to Reproduce):**
  1. Đăng nhập bằng tài khoản Admin.
  2. Mở tab **Mã Giảm Giá**.
  3. Nhập mã coupon đã tồn tại trong danh sách, ví dụ `SAVE10`, cùng các trường còn lại hợp lệ.
  4. Bấm **Tạo mã** và quan sát thông báo lỗi/response.
- **Kết quả mong đợi (Expected Output):** Server trả lỗi xung đột/validation và thông báo nghiệp vụ rằng mã giảm giá đã tồn tại.
- **Kết quả thực tế (Actual Output):** Server trả HTTP 500 với body chứa lỗi `SQLITE_CONSTRAINT: UNIQUE constraint failed: coupons.code`.
- **Bằng chứng thực thi:** Test case `TC07`; `TC19` cũng quan sát lỗi tương tự ở một request đồng thời.
- **Đường dẫn GitHub Issue:** [GitHub Issue #22](#)
- **Ảnh chụp minh họa (Bug Screenshot):**



## BUG-FR17-09: Xóa coupon không tồn tại vẫn báo thành công

- **Mô tả lỗi:** Endpoint xóa coupon phản hồi thành công ngay cả khi ID không tồn tại hoặc ID nằm ngoài miền hợp lệ. Từ góc nhìn API client, hệ thống không phân biệt thao tác xóa thật với thao tác xóa không tác động dữ liệu.
- **Các bước tái hiện (Steps to Reproduce):**
  1. Đăng nhập bằng tài khoản Admin.
  2. Vì giao diện chỉ hiển thị nút xóa cho coupon đang tồn tại trong danh sách, gửi trực tiếp request `DELETE /api/admin/coupons/999999`.
  3. Gửi thêm request `DELETE /api/admin/coupons/0` để kiểm tra biên ID không hợp lệ.
  4. Quan sát response.
- **Kết quả mong đợi (Expected Output):** Server trả lỗi không tìm thấy hoặc lỗi validation ID, và UI/client giữ nguyên danh sách coupon.

- **Kết quả thực tế (Actual Output):** Cả hai request đều trả HTTP 200 với body `{"message":"Coupon deleted"}`.
- **Bảng chứng thực thi:** Test case **TC18** và **TC-BVA-09**.
  - Đường dẫn GitHub Issue: [GitHub Issue #23](#)
- **Ảnh chụp minh họa (Bug Screenshot):**

```
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -X POST http://localhost:3000/api/login \
-H "Content-Type: application/json" \
-d '{"email": "admin@eshop.com", "password": "Admin123!"}'

{"message":"Login successful","token":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwicm9sZSI6ImFkbWluIiwiaWF0IjoxNzg5NTA3NDQ1fQ.54jWfe1MYSADBbJKLu16DTlKu_cNY_UxS33BvV_QXDw","user":{"id":1,"name":"Admin User","email":"admin@eshop.com","password":"Admin123!","role":"admin","login_attempts":0,"locked_until":null,"reset_token":null,"shipping_address":null,"phone":null}}
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -i -X DELETE http://localhost:3000/api/admin/coupons/999999 \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwicm9sZSI6ImFkbWluIiwiaWF0IjoxNzg5NTA3NDQ1fQ.54jWfe1MYSADBbJKLu16DTlKu_cNY_UxS33BvV_QXDw"

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 28
ETag: W/"1c-q1LucmpgMOD+46/oGM8fayoQTxQ"
Date: Wed, 08 Jul 2026 10:44:54 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Coupon deleted"}
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -i -X DELETE http://localhost:3000/api/admin/coupons/0 \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwicm9sZSI6ImFkbWluIiwiaWF0IjoxNzg5NTA3NDQ1fQ.54jWfe1MYSADBbJKLu16DTlKu_cNY_UxS33BvV_QXDw"

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 28
ETag: W/"1c-q1LucmpgMOD+46/oGM8fayoQTxQ"
Date: Wed, 08 Jul 2026 10:45:15 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Coupon deleted"}
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 %
```

Danh sách lỗi tổng hợp - FR-07: Giỏ hàng (Shopping Cart)

| Mã Bug      | Tên lỗi (Bug Name)                                    | Mã TC phát hiện                   | Mô tả hành vi lỗi quan sát                                                                                    | Độ nghiêm trọng (Severity) | Trạng thái |
|-------------|-------------------------------------------------------|-----------------------------------|---------------------------------------------------------------------------------------------------------------|----------------------------|------------|
| BUG-FR07-01 | API giỏ hàng không gộp sản phẩm trùng                 | TC02                              | Khi thêm cùng một sản phẩm hai lần, GET /api/cart trả 2 dòng trùng id thay vì tăng số lượng của dòng hiện có. | High                       | Open       |
| BUG-FR07-02 | API giỏ hàng không validate quantity                  | TC04, TC05, TC06, TC07, TC-BVA-01 | API vẫn thêm sản phẩm khi thiếu quantity, quantity sai kiểu, bằng 0 hoặc âm.                                  | High                       | Open       |
| BUG-FR07-03 | API giỏ hàng không validate dữ liệu sản phẩm bắt buộc | TC08, TC09, TC10                  | API vẫn thêm item khi thiếu id, name rỗng hoặc price âm, làm giỏ có dữ liệu không hợp lệ.                     | High                       | Open       |
| BUG-FR07-04 | API giỏ hàng trả HTML 404 cho phương                  | TC19                              | Khi kiểm tra robust API với các phương thức ngoài spec (PUT/PATCH/DELETE                                      | Low                        | Open       |

| Mã Bug      | Tên lỗi (Bug Name)                                      | Mã TC phát hiện                        | Mô tả hành vi lỗi quan sát                                                                                                 | Độ nghiêm trọng (Severity) | Trạng thái |
|-------------|---------------------------------------------------------|----------------------------------------|----------------------------------------------------------------------------------------------------------------------------|----------------------------|------------|
|             | thức ngoài hợp đồng API                                 |                                        | /api/cart), hệ thống trả trang HTML mặc định thay vì phản hồi lỗi API nhất quán.                                           |                            |            |
| BUG-FR07-05 | Mobile cart dùng sai nhãn tổng tiền                     | TC01, TC18, TC-BVA-07, TC-BVA-08       | UI mobile hiển thị Tổng tạm tính thay vì nhãn yêu cầu "Tổng cộng".                                                         | Medium                     | Open       |
| BUG-FR07-06 | Mobile cart thiếu control tăng/giảm số lượng bằng +/-   | TC11, TC12, TC13, TC-BVA-04, TC-BVA-05 | Màn giỏ chỉ có input số lượng, không có nút +/- như luồng test yêu cầu; thao tác giảm bằng nút không thể thực hiện.        | Medium                     | Open       |
| BUG-FR07-07 | Xóa sản phẩm trong mobile cart không có dialog xác nhận | TC14, TC15, TC-BVA-04                  | Bấm Xóa xóa item ngay, không hiển thị dialog nên không có lựa chọn Confirm/Cancel.                                         | High                       | Open       |
| BUG-FR07-08 | Empty cart mobile thiếu hình minh họa                   | TC17, TC-BVA-06                        | Khi giỏ trống, UI chỉ hiển thị text Giỏ hàng của bạn đang trống và nút tiếp tục mua sắm, không quan sát thấy illustration. | Low                        | Open       |

BUG-FR07-01: API giỏ hàng không gộp sản phẩm trùng

- Mã TC liên quan: TC02
- Steps to Reproduce:
  1. Đăng nhập bằng tài khoản user hợp lệ để lấy JWT.
  2. Gửi POST /api/cart với sản phẩm hợp lệ id=6, quantity=1.
  3. Gửi lại POST /api/cart với cùng id=6, quantity=1.
  4. Gửi GET /api/cart.
- Expected Output: Giỏ hàng chỉ có một dòng sản phẩm id=6, số lượng tăng thành 2.
- Actual Output: API trả 200 OK cho cả hai lần thêm, nhưng GET /api/cart trả 2 dòng trùng id=6, mỗi dòng quantity=1.
- Severity: High
- GitHub Issue: BUG-FR07-01

- **Screenshot:**

```

• (base) HB4305 ~/KhoChua/DH/Năm3/HK3/Kiểm thử phần mềm/HW02 % TOKEN=$(curl -s -X POST http://localhost:3000/api/login \
-H "Content-Type: application/json" \
-d '{"email":"test@eshop.com","password":"Test1234!"}' | jq -r '.token')
○ (base) HB4305 ~/KhoChua/DH/Năm3/HK3/Kiểm thử phần mềm/HW02 %
○ (base) HB4305 ~/KhoChua/DH/Năm3/HK3/Kiểm thử phần mềm/HW02 %
• (base) HB4305 ~/KhoChua/DH/Năm3/HK3/Kiểm thử phần mềm/HW02 % curl -i -X POST http://localhost:3000/api/cart \
-H "Authorization: Bearer $TOKEN" \
-H "Content-Type: application/json" \
-d '{"id":6,"name":"Test product duplicate","price":100000,"quantity":1}'

curl -i -X POST http://localhost:3000/api/cart \
-H "Authorization: Bearer $TOKEN" \
-H "Content-Type: application/json" \
-d '{"id":6,"name":"Test product duplicate","price":100000,"quantity":1}'

curl -i -X GET http://localhost:3000/api/cart \
-H "Authorization: Bearer $TOKEN"

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 27
ETag: W/"1b-TJw0U+vjK3qJFSNCd2YreHR6oao"
Date: Wed, 08 Jul 2026 16:58:01 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Added to cart"}HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 27
ETag: W/"1b-TJw0U+vjK3qJFSNCd2YreHR6oao"
Date: Wed, 08 Jul 2026 16:58:01 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Added to cart"}HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 139
ETag: W/"8b-8Vm0Efnx7YUJ7LRaym6v3FCCLoM"
Date: Wed, 08 Jul 2026 16:58:01 GMT
Connection: keep-alive
Keep-Alive: timeout=5

[{"id":6,"name":"Test product duplicate","price":100000,"quantity":1},{"id":6,"name":"Test product duplicate","price":100000,"quantity":1}]
○ (base) HB4305 ~/KhoChua/DH/Năm3/HK3/Kiểm thử phần mềm/HW02 %

```

## BUG-FR07-02: API giỏ hàng không validate **quantity**

- **Mã TC liên quan:** TC04, TC05, TC06, TC07, TC-BVA-01
- **Steps to Reproduce:**
  1. Đăng nhập bằng tài khoản user hợp lệ để lấy JWT.
  2. Gửi **POST /api/cart** với lần lượt các payload: thiếu **quantity**, **quantity="abc"**, **quantity=0**, **quantity=-1**.
  3. Gửi **GET /api/cart**.
- **Expected Output:** API trả lỗi validation và giỏ hàng không thay đổi.
- **Actual Output:** API đều trả **200 OK** với body **{"message":"Added to cart"}**; **GET /api/cart** cho thấy item thiếu **quantity**, item **quantity:"abc"**, item **quantity:0** và item **quantity:-1** đều được lưu.
- **Severity:** High
- **GitHub Issue:** [BUG-FR07-02](#)



- **Screenshot:**

```
(base) HB4305 ~/KhoChua/0H/Năm3/HK3/Kiểm thử phần mềm/HW02 % curl -i -X POST http://localhost:3000/api/cart \
-H "Authorization: Bearer $TOKEN" \
-H "Content-Type: application/json" \
-d '{"id":701,"name":"Missing quantity","price":100000}'

curl -i -X POST http://localhost:3000/api/cart \
-H "Authorization: Bearer $TOKEN" \
-H "Content-Type: application/json" \
-d '{"id":702,"name":"String quantity","price":100000,"quantity":"abc"}'

curl -i -X POST http://localhost:3000/api/cart \
-H "Authorization: Bearer $TOKEN" \
-H "Content-Type: application/json" \
-d '{"id":703,"name":"Zero quantity","price":100000,"quantity":0}'

curl -i -X POST http://localhost:3000/api/cart \
-H "Authorization: Bearer $TOKEN" \
-H "Content-Type: application/json" \
-d '{"id":704,"name":"Negative quantity","price":100000,"quantity":-1}'

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 27
ETag: W/"1b-TJw0U+vjK3qJFSNCd2YreHR6oao"
Date: Wed, 08 Jul 2026 17:02:04 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Added to cart"}HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 27
ETag: W/"1b-TJw0U+vjK3qJFSNCd2YreHR6oao"
Date: Wed, 08 Jul 2026 17:02:04 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Added to cart"}HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 27
ETag: W/"1b-TJw0U+vjK3qJFSNCd2YreHR6oao"
Date: Wed, 08 Jul 2026 17:02:04 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Added to cart"}HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 27
ETag: W/"1b-TJw0U+vjK3qJFSNCd2YreHR6oao"
Date: Wed, 08 Jul 2026 17:02:04 GMT
Connection: keep-alive
```

## BUG-FR07-03: API giỏ hàng không validate dữ liệu sản phẩm bắt buộc

- **Mã TC liên quan:** TC08, TC09, TC10
- **Steps to Reproduce:**
  1. Đăng nhập bằng tài khoản user hợp lệ để lấy JWT.
  2. Gửi **POST** `/api/cart` với payload thiếu `id`.
  3. Gửi **POST** `/api/cart` với `price=-100000`.
  4. Gửi **POST** `/api/cart` với `name=""`.
  5. Gửi **GET** `/api/cart`.
- **Expected Output:** API trả lỗi validation và không thêm các item thiếu/sai dữ liệu bắt buộc.
- **Actual Output:** API đều trả **200 OK** với body `{"message":"Added to cart"}`; giỏ hàng lưu item không có `id`, item có giá âm và item có tên rỗng.
- **Severity:** High
- **GitHub Issue:** [BUG-FR07-03](#)

- **Screenshot:**

```

● (base) HB4305 ~/KhoChua/ĐH/Năm3/HK3/Kiểm thử phần mềm/HW02 % curl -i -X POST http://localhost:3000/api/cart \
 -H "Authorization: Bearer $TOKEN" \
 -H "Content-Type: application/json" \
 -d '{"name":"Missing id","price":100000,"quantity":1}'

curl -i -X POST http://localhost:3000/api/cart \
 -H "Authorization: Bearer $TOKEN" \
 -H "Content-Type: application/json" \
 -d '{"id":801,"name":"","price":100000,"quantity":1}'

curl -i -X POST http://localhost:3000/api/cart \
 -H "Authorization: Bearer $TOKEN" \
 -H "Content-Type: application/json" \
 -d '{"id":802,"name":"Negative price","price":-100000,"quantity":1}'
HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 27
ETag: W/"1b-TJw0U+vjk3qJFSNCd2YreHR6oao"
Date: Wed, 08 Jul 2026 17:06:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Added to cart"}HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 27
ETag: W/"1b-TJw0U+vjk3qJFSNCd2YreHR6oao"
Date: Wed, 08 Jul 2026 17:06:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Added to cart"}HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 27
ETag: W/"1b-TJw0U+vjk3qJFSNCd2YreHR6oao"
Date: Wed, 08 Jul 2026 17:06:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"message":"Added to cart"}
○ (base) HB4305 ~/KhoChua/ĐH/Năm3/HK3/Kiểm thử phần mềm/HW02 %

```

## BUG-FR07-04: API giỏ hàng trả HTML 404 cho phương thức ngoài hợp đồng API

- **Mã TC liên quan:** TC19
- **Steps to Reproduce:**
  1. Đăng nhập bằng tài khoản user hợp lệ để lấy JWT.
  2. Gửi các request không hỗ trợ: **PUT /api/cart**, **PATCH /api/cart**, **DELETE /api/cart/6**.
- **Expected Output:** Vì các phương thức này không nằm trong API spec chính thức, hệ thống nên từ chối nhất quán và không thay đổi giỏ hàng; phản hồi lỗi nên phù hợp với API client.
- **Actual Output:** API trả HTTP **404 Not Found** với trang HTML mặc định như **Cannot PUT /api/cart**, **Cannot PATCH /api/cart**, **Cannot DELETE /api/cart/6**.
- **Severity:** Low
- **GitHub Issue:** [BUG-FR07-04](#)



- **Screenshot:**

```
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 % curl -i -X PUT http://localhost:3000/api/cart \
-H "Authorization: Bearer $TOKEN" \
-H "Content-Type: application/json" \
-d '{"id":6,"quantity":2}'

curl -i -X PATCH http://localhost:3000/api/cart \
-H "Authorization: Bearer $TOKEN" \
-H "Content-Type: application/json" \
-d '{"id":6,"quantity":2}'

curl -i -X DELETE http://localhost:3000/api/cart/6 \
-H "Authorization: Bearer $TOKEN"
HTTP/1.1 404 Not Found
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Security-Policy: default-src 'none'
X-Content-Type-Options: nosniff
Content-Type: text/html; charset=utf-8
Content-Length: 147
Date: Wed, 08 Jul 2026 17:08:27 GMT
Connection: keep-alive
Keep-Alive: timeout=5

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error</title>
</head>
<body>
<pre>Cannot PUT /api/cart</pre>
</body>
</html>
HTTP/1.1 404 Not Found
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Security-Policy: default-src 'none'
X-Content-Type-Options: nosniff
Content-Type: text/html; charset=utf-8
Content-Length: 149
Date: Wed, 08 Jul 2026 17:08:27 GMT
Connection: keep-alive
Keep-Alive: timeout=5

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error</title>
</head>
<body>
<pre>Cannot PATCH /api/cart</pre>
</body>
</html>
HTTP/1.1 404 Not Found
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Security-Policy: default-src 'none'
X-Content-Type-Options: nosniff
Content-Type: text/html; charset=utf-8
Content-Length: 152
Date: Wed, 08 Jul 2026 17:08:27 GMT
Connection: keep-alive
Keep-Alive: timeout=5

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error</title>
</head>
<body>
<pre>Cannot DELETE /api/cart/6</pre>
</body>
</html>
(base) HB4305 ~/KhoChua/DH/Nam3/HK3/Kiểm thử phần mềm/HW02 %
```

## BUG-FR07-05: Mobile cart dùng sai nhãn tổng tiền

- **Mã TC liên quan:** **TC01**, **TC18**, **TC-BVA-07**, **TC-BVA-08**
- **Steps to Reproduce:**
  1. Mở mobile UI qua Expo.
  2. Thêm một hoặc nhiều sản phẩm vào giỏ.
  3. Mở màn hình giỏ hàng.
- **Expected Output:** Khu vực tổng tiền hiển thị nhãn "**Tổng cộng**".
- **Actual Output:** UI mobile hiển thị **Tổng tạm tính: ...** cho cả giỏ có một item và nhiều item.
- **Severity:** Medium
- **GitHub Issue:** [BUG-FR07-05](#)

- **Screenshot:**

00:15 

 Camera



EShop Mobile

Đăng nhậpGiỏ (1)

Giỏ Hàng

iPhone 15 Pro Max

Giá: 30.000.000 đ

Số lượng: 

1

Thành tiền: 30.000.000 đ

Xóa

35 / 45



BUG-FR07-06: Mobile cart thiếu control tăng/giảm số lượng bằng +/-

- **Mã TC liên quan:** [TC11](#), [TC12](#), [TC13](#), [TC-BVA-04](#), [TC-BVA-05](#)
- **Steps to Reproduce:**
  1. Mở mobile UI qua Expo.
  2. Thêm sản phẩm vào giỏ.
  3. Mở màn hình giỏ hàng và quan sát khu vực số lượng.
- **Expected Output:** Người dùng có thể tăng/giảm số lượng bằng control +/-, và hệ thống không cho giảm dưới [1](#).
- **Actual Output:** Màn giỏ chỉ hiển thị input số lượng, không có nút + hoặc -; không thể thực hiện thao tác giảm số lượng bằng nút như yêu cầu trong test case.
- **Severity:** Medium
- **GitHub Issue:** [BUG-FR07-06](#)

- **Screenshot:**

00:15 

 Camera



EShop Mobile

Đăng nhậpGiỏ (1)

Giỏ Hàng

iPhone 15 Pro Max

Giá: 30.000.000 đ

Số lượng: 

1

Thành tiền: 30.000.000 đ

Xóa

38 / 45



BUG-FR07-07: Xóa sản phẩm trong mobile cart không có dialog xác nhận

- **Mã TC liên quan:** [TC14](#), [TC15](#), [TC-BVA-04](#)
- **Steps to Reproduce:**
  1. Mở mobile UI qua Expo.
  2. Thêm một sản phẩm vào giỏ.
  3. Mở màn hình giỏ hàng.
  4. Bấm **Xóa** trên dòng sản phẩm.
- **Expected Output:** UI hiển thị dialog xác nhận trước khi xóa, cho phép người dùng Confirm hoặc Cancel.
- **Actual Output:** Không có dialog xác nhận; item bị xóa ngay, badge chuyển về [Giỏ \(0\)](#) và màn hình hiển thị giỏ trống.
- **Severity:** High
- **GitHub Issue:** [BUG-FR07-07](#)



- **Screenshot:**

00:21 ❤️

**EShop Mobile**

Đăng nhập Giỏ (0)

## Giỏ Hàng

Giỏ hàng của bạn đang trống

[Tiếp tục mua sắm](#)

© 2026 EShop SUT. Dành cho mục đích kiểm thử.

#### BUG-FR07-08: Empty cart mobile thiếu hình minh họa

- **Mã TC liên quan:** [TC17](#), [TC-BVA-06](#)
- **Steps to Reproduce:**
  1. Mở mobile UI qua Expo.
  2. Đảm bảo giỏ hàng trống.
  3. Mở màn hình giỏ hàng.
- **Expected Output:** UI hiển thị hình minh họa và thông báo rõ ràng rằng giỏ hàng đang trống.
- **Actual Output:** UI chỉ hiển thị text [Giỏ hàng của bạn đang trống](#) và nút [Tiếp tục mua sắm](#); không quan sát thấy hình minh họa.
- **Severity:** Low
- **GitHub Issue:** [BUG-FR07-08](#)

- **Screenshot:**

00:21 ❤️

**EShop Mobile**

Đăng nhập    Giỏ (0)

## Giỏ Hàng

Giỏ hàng của bạn đang trống

[Tiếp tục mua sắm](#)

© 2026 EShop SUT. Dành cho mục đích kiểm thử.